

Tenable Vulnerability Management Report

Tenable Vulnerability Management

Sun, 14 Jun 2026 00:36:27 UTC

Table Of Contents

Audits FAILED.....	4
•1.1.2.3.1 Ensure separate partition exists for /home.....	5
•6.2.3.7 Ensure unsuccessful file access attempts are collected.....	9
•6.2.3.19 Ensure kernel module loading unloading and modification is collected.....	13
•1.1.1.8 Ensure udf kernel module is not available.....	17
•6.2.3.13 Ensure file deletion events by users are collected.....	19
•6.2.3.9 Ensure discretionary access control permission modification events are collected.....	24
•6.2.1.3 Ensure auditing for processes that start prior to auditd is enabled.....	34
•6.2.3.18 Ensure successful and unsuccessful attempts to use the usermod command are collected.....	37
•6.2.3.1 Ensure changes to system administration scope (sudoers) is collected.....	40
•6.2.3.11 Ensure session initiation information is collected.....	43
•6.2.3.16 Ensure successful and unsuccessful attempts to use the setfacl command are collected.....	47
•6.2.3.15 Ensure successful and unsuccessful attempts to use the chcon command are collected.....	50
•3.2.4 Ensure sctp kernel module is not available.....	53
•6.2.3.17 Ensure successful and unsuccessful attempts to use the chacl command are collected.....	57
•6.2.2.1 Ensure audit log storage size is configured.....	60
•1.1.2.5.1 Ensure separate partition exists for /var/tmp.....	62
•6.2.2.4 Ensure system warns when audit logs are low on space.....	66
•6.2.3.8 Ensure events that modify user/group information are collected.....	70
•5.4.1.2 Ensure minimum password days is configured.....	75
•6.2.3.2 Ensure actions as another user are always logged.....	77
•1.3.1.4 Ensure all AppArmor Profiles are enforcing.....	80
•1.1.2.6.1 Ensure separate partition exists for /var/log.....	89
•6.2.3.12 Ensure login and logout events are collected.....	91
•6.2.2.3 Ensure system is disabled when audit logs are full.....	94
•3.2.2 Ensure tipc kernel module is not available.....	98
•6.2.3.20 Ensure the audit configuration is immutable.....	102
•6.2.3.10 Ensure successful file system mounts are collected.....	108
•6.2.3.4 Ensure events that modify date and time information are collected.....	112
•6.2.3.6 Ensure use of privileged commands are collected.....	117
•6.2.3.14 Ensure events that modify the system's Mandatory Access Controls are collected.....	121
•1.1.2.4.1 Ensure separate partition exists for /var.....	125
•6.2.1.4 Ensure audit_backlog_limit is sufficient.....	129
•5.1.8 Ensure sshd DisableForwarding is enabled.....	133
•5.2.4 Ensure users must provide password for privilege escalation.....	135
•6.3.3 Ensure cryptographic mechanisms are used to protect the integrity of audit tools.....	138
•5.3.3.1.3 Ensure password failed attempts lockout includes root account.....	140
•1.1.2.7.1 Ensure separate partition exists for /var/log/audit.....	143
•6.2.3.5 Ensure events that modify the system's network environment are collected.....	145
•1.1.1.6 Ensure overlaysfs kernel module is not available.....	151
•6.2.2.2 Ensure audit logs are not automatically deleted.....	153
Audits SKIPPED.....	155
Audits PASSED.....	156

•6.2.4.9 Ensure audit tools owner is configured.....	157
•6.2.1.1 Ensure auditd packages are installed.....	162
•6.2.3.3 Ensure events that modify the sudo log file are collected.....	166
•6.2.4.10 Ensure audit tools group owner is configured.....	169
•6.2.4.5 Ensure audit configuration files mode is configured.....	174
•1.7.1 Ensure GDM is removed.....	179
•2.1.20 Ensure X window server services are not in use.....	181
•6.2.3.21 Ensure the running and on disk configuration is the same.....	183
•6.2.1.2 Ensure auditd service is enabled and active.....	186
•6.2.4.8 Ensure audit tools mode is configured.....	189
•6.2.4.2 Ensure audit log files owner is configured.....	194
•6.2.4.1 Ensure audit log files mode is configured.....	199
•6.2.4.7 Ensure audit configuration files group owner is configured.....	204
•3.2.1 Ensure dccp kernel module is not available.....	209
•CIS_Ubuntu_Linux_24.04_LTS_v1.0.0_L2_Server.audit from CIS Ubuntu Linux 24.04 LTS 1.0.0.....	212
•1.1.1.7 Ensure squashfs kernel module is not available.....	213
•3.2.3 Ensure rds kernel module is not available.....	215
•6.2.4.4 Ensure the audit log file directory mode is configured.....	218
•6.2.4.6 Ensure audit configuration files owner is configured.....	223
•6.2.4.3 Ensure audit log files group owner is configured.....	228
•5.1.9 Ensure sshd GSSAPIAuthentication is disabled.....	233
•5.4.3.1 Ensure nologin is not listed in /etc/shells.....	237

Audits ERROR,INFO,WARNING.....	240
---------------------------------------	------------

Audits FAILED

1.1.2.3.1 Ensure separate partition exists for /home

Info

The /home directory is used to support disk storage needs of local users. The default installation only creates a single / partition.

Since the /home directory contains user generated data, there is a risk of resource exhaustion.

It will essentially have the whole disk available to fill up and impact the system as a whole.

In addition, other operations on the system could fill up the disk unrelated to /home and impact all local users.

Configuring /home as its own file system allows an administrator to set additional mount options such as noexec/nosuid/nODEV.

These options limit an attacker's ability to create exploits on the system.

In the case of /home options such as usrquota/grpquota may be considered to limit the impact that users can have on each other with regards to disk resource exhaustion.

Other options allow for specific behavior.

See man mount for exact details regarding filesystem-independent and filesystem-specific options. As /home contains user data, care should be taken to ensure the security and integrity of the data and mount point.

Solution

For new installations, during installation create a custom partition setup and specify a separate partition for /home. For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate. Impact: Resizing filesystems is a common activity in cloud-hosted servers.

Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations.

The use of these additional tools may introduce their own security considerations.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.4.6
800-171	3.4.7
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.04.06
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	CM-7

800-53	MP-2
800-53R5	CM-7
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10

ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	CM-7
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f
NIAV2	SS13c

NIAV2	SS15a
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	2.2.2
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	5.1
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

The following file(s) do not contain "[\s]+/home[\s]+":
 /proc/self/mountinfo

6.2.3.7 Ensure unsuccessful file access attempts are collected

Info

Monitor for unsuccessful attempts to access files.

The following parameters are associated with system calls that control files: - creation - creat - opening - open, openat - truncation - truncate, ftruncate An audit log record will only be written if all of the following criteria is met for the user when trying to access a file: - a non-privileged user (auid>=UID_MIN) - is not a Daemon event (auid=4294967295/unset/-1) - if the system call returned EACCES (permission denied) or EPERM (some other permanent error associated with the specific system call) Failed attempts to open, create or truncate files could be an indication that an individual or process is trying to gain unauthorized access to the system.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor unsuccessful file access attempts. Example: # { UID_MIN=\$(awk '/^\s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-EACCES -F auid>=\${UID_MIN} -F auid!=unset -k access -a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-EPERM -F auid>=\${UID_MIN} -F auid!=unset -k access -a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-EACCES -F auid>=\${UID_MIN} -F auid!=unset -k access -a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-EPERM -F auid>=\${UID_MIN} -F auid!=unset -k access " >> /etc/audit/rules.d/50-access.rules | | printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)

CSCV7	14.9
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f

NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

FAILED - auditctl b32 EPERM

The command 'UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&(/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -F *exit=-EPERM/ &&/ -S/ &&/creat/ &&/open/ &&/truncate/ &&(/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

FAILED - auditctl b64 EACCES

The command 'UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -F *exit=-EACCES/ &&/ -S/ &&/creat/ &&/open/ &&/truncate/ &&(/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

FAILED - auditctl b64 EPERM

The command 'UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -F *exit=-EPERM/ &&/ -S/ &&/creat/ &&/open/ &&/truncate/ &&(/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```
-----  
FAILED - auditctl b32 EACCES  
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!  
=unset/||/ -F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -F *exit=-  
EACCES/ &&/ -S/ &&/creat/ &&/open/ &&/truncate/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /  
bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable  
'UID_MIN' is unset.\n" returned :
```

fail

```
-----  
FAILED - b64 EPERM  
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *uid!=unset/||/  
-F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -F *exit=-EPERM/ &&/ -S/  
&&/creat/ &&/open/ &&/truncate/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/  
*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR:  
Variable 'UID_MIN' is unset.\n" returned :
```

fail

```
-----  
FAILED - b32 EACCES  
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!=unset/||/ -  
F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -F *exit=-EACCES/ &&/ -S/  
&&/creat/ &&/open/ &&/truncate/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/  
*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR:  
Variable 'UID_MIN' is unset.\n" returned :
```

fail

```
-----  
FAILED - b32 EPERM  
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!=unset/||/  
-F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -F *exit=-EPERM/ &&/ -S/  
&&/creat/ &&/open/ &&/truncate/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/  
*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR:  
Variable 'UID_MIN' is unset.\n" returned :
```

fail

```
-----  
FAILED - b64 EACCES  
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *uid!=unset/||/ -  
F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -F *exit=-EACCES/ &&/ -S/  
&&/creat/ &&/open/ &&/truncate/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/  
*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR:  
Variable 'UID_MIN' is unset.\n" returned :
```

fail

6.2.3.19 Ensure kernel module loading unloading and modification is collected

Info

Monitor the loading and unloading of kernel modules.
All the loading / listing / dependency checking of modules is done by kmod via symbolic links. The following system calls control loading and unloading of modules: - init_module - load a module - finit_module - load a module (used when the overhead of using cryptographically signed modules to determine the authenticity of a module can be avoided) - delete_module - delete a module - create_module - create a loadable module entry - query_module - query the kernel for various bits pertaining to modules Any execution of the loading and unloading module programs and system calls will trigger an audit record with an identifier of modules. Monitoring the use of all the various ways to manipulate kernel modules could provide system administrators with evidence that an unauthorized change was made to a kernel module, possibly compromising the security of the system.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor kernel module modification. Example: `#!/usr/bin/env bash { UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs) [-n "${UID_MIN}"] && printf " -a always,exit -F arch=b64 -S init_module,finit_module,delete_module,create_module,query_module -F auid>=${UID_MIN} -F auid!=unset -k kernel_modules -a always,exit -F path=/usr/bin/kmod -F perm=x -F auid>=${UID_MIN} -F auid!=unset -k kernel_modules " >> /etc/audit/rules.d/50-kernel_modules.rules | | printf "ERROR: Variable 'UID_MIN' is unset.\n" }` Load audit rules Merge and load the rules into active configuration: `# augenrules --load` Check if reboot is required. `# if [[$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6
800-53R5	AU-3
800-53R5	CM-6
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)

CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	6.2
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	CM-6

LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - rules path
The command script with multiple lines returned :

fail
```

```
-----
FAILED - rules arch
The command script with multiple lines returned :
```

fail

FAILED - auditctl path
The command script with multiple lines returned :

fail

FAILED - auditctl arch
The command script with multiple lines returned :

fail

PASSED - symlinks
The command script with multiple lines returned :

OK: "/usr/sbin/lsmmod"
OK: "/usr/sbin/rmmod"
OK: "/usr/sbin/insmod"
OK: "/usr/sbin/modinfo"
OK: "/usr/sbin/modprobe"
OK: "/usr/sbin/depmod"
pass

1.1.1.8 Ensure udf kernel module is not available

Info

The udf filesystem type is the universal disk format used to implement ISO/IEC 13346 and ECMA-167 specifications.

This is an open vendor filesystem type for data storage on a broad range of media.

This filesystem type is necessary to support writing DVDs and newer optical disc formats. Removing support for unneeded filesystem types reduces the local attack surface of the system.

If this filesystem type is not needed, disable it.

Solution

Run the following script to unload and disable the udf module: - IF - the udf kernel module is available in ANY installed kernel: - Create a file ending in .conf with install udf /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist udf in the /etc/modprobe.d/ directory - Run modprobe -r udf 2>/dev/null; rmmod udf 2>/dev/null to remove udf from the kernel - IF - the udf kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary #!/usr/bin/env bash { a_output2=() a_output3=() l_dl="" l_mod_name="udf" l_mod_type="fs" l_mod_path="\$(readlink -f /lib/modules/**/kernel/\$l_mod_type | sort -u)" f_module_fix() { l_dl="y" a_showconfig=() while IFS= read -r l_showconfig; do a_showconfig+="\$l_showconfig" done < <(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+""\${l_mod_chk_name}/-/_)'\b' if lsmod | grep "\$l_mod_chk_name" && /dev/null; then a_output2+=(" - unloading kernel module: \"\$l_mod_name\"") modprobe -r "\$l_mod_chk_name" 2>/dev/null; rmmod "\$l_mod_name" 2>/dev/null fi if ! grep -Pq -- '\binstall\h+""\${l_mod_chk_name}/-/_)'\b' <<< "\${a_showconfig[*]}"; then a_output2+=(" - setting kernel module: \"\$l_mod_name\" to \"\$(readlink -f /bin/false)\"") printf '%s\n' "install \$l_mod_chk_name \$(readlink -f /bin/false)" >> /etc/modprobe.d/"\$l_mod_name".conf fi if ! grep -Pq -- '\bblacklist\h+""\${l_mod_chk_name}/-/_)'\b' <<< "\${a_showconfig[*]}"; then a_output2+=(" - denylisting kernel module: \"\$l_mod_name\"") printf '%s\n' "blacklist \$l_mod_chk_name" >> /etc/modprobe.d/"\$l_mod_name".conf fi } for l_mod_base_directory in \$l_mod_path; do # Check if the module exists on the system if [-d "\$l_mod_base_directory/\${l_mod_name}/-/_)'"] && [-n "\$(ls -A "\$l_mod_base_directory/\${l_mod_name}/-/_)'"]]; then a_output3+=(" - \"\$l_mod_base_directory\"") l_mod_chk_name="\$l_mod_name" [["\$l_mod_name" =~ overlay]] && l_mod_chk_name="\${l_mod_name::-2}" ["\$l_dl" != "y"] && f_module_fix else printf '%s\n' " - kernel module: \"\$l_mod_name\" doesn't exist in \"\$l_mod_base_directory\"" fi done ["\${#a_output3[@]}" -gt 0] && printf '%s\n' "" -- INFO -- " - module: \"\$l_mod_name\" exists in: " "\${a_output3[@]}" ["\${#a_output2[@]}" -gt 0] && printf '%s\n' "" "\${a_output2[@]}" | | printf '%s\n' "" " - No changes needed" printf '%s\n' "" " - remediation of kernel module: \"\$l_mod_name\" complete" "" } Impact: Microsoft Azure requires the usage of udf. udf should not be disabled on systems run on Microsoft Azure.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53R5	CM-7
CSCV7	9.2
CSCV8	4.8
CSF	PR.IP-1
CSF	PR.PT-3

CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
-- INFO --
- module: "udf" exists in:
  - "/usr/lib/modules/6.17.0-1018-azure/kernel/fs"

- Audit Result:
  ** FAIL **
- Reason(s) for audit failure:
  - kernel module: "udf" is loaded
  - kernel module: "udf" is loadable
  - kernel module: "udf" is not deny listed
```

6.2.3.13 Ensure file deletion events by users are collected

Info

Monitor the use of system calls associated with the deletion or renaming of files and file attributes. This configuration statement sets up monitoring for: - unlink - remove a file - unlinkat - remove a file attribute - rename - rename a file - renameat rename a file attributesystem calls and tags them with the identifier "delete". Monitoring these calls from non-privileged users could provide a system administrator with evidence that inappropriate removal of files and file attributes associated with protected files is occurring. While this audit option will look at all events, system administrators will want to look for specific privileged files that are being deleted or altered.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor file deletion events by users. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F arch=b64 -S rename,unlink,unlinkat,renameat -F auid>=\${UID_MIN} -F auid!=unset -F key=delete -a always,exit -F arch=b32 -S rename,unlink,unlinkat,renameat -F auid>=\${UID_MIN} -F auid!=unset -F key=delete " >> /etc/audit/rules.d/50-delete.rules | | printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.13.1
800-171	3.13.5
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.13.01
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	SC-7
800-53R5	AU-12
800-53R5	SC-7
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)

CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CN-L3	8.1.10.6(j)
CSCV7	6.2
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.AC-5
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-4
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.5.28

ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.16
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.13.1.3
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SC-7
LEVEL	2A
NESA	T3.6.2
NESA	T4.5.4
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	GS1
NIAV2	GS2a
NIAV2	GS2b
PCI-DSSV3.2.1	1.1
PCI-DSSV3.2.1	1.2
PCI-DSSV3.2.1	1.2.1
PCI-DSSV3.2.1	1.3
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3

PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	1.2.1
PCI-DSSV4.0	1.4.1
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4
TBA-FIISB	43.1

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

FAILED - b32 unlink

The command 'UID_MIN=\$(awk '/^\s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -S/ &&/unlink/||/ rename/||/unlinkat/||/renameat/) &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

FAILED - auditctl b64 unlink

The command 'UID_MIN=\$(awk '/^\s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -S/ &&/unlink/||/rename/||/unlinkat/||/renameat/) &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

FAILED - auditctl b32 unlink

The command 'UID_MIN=\$(awk '/^\s*UID_MIN/{print \$2}' /etc/login.defs); [-n "\${UID_MIN}"] && auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=\${UID_MIN}/ &&/ -S/ &&/unlink/||/rename/||/unlinkat/||/renameat/) &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```

-----
FAILED - b64 unlink
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *uid!=unset/||/
-F *uid!=-1/||/ -F *uid!=4294967295/) &&/ -F *uid>=${UID_MIN}/ &&/ -S/ &&(/unlink/||/
rename/||/unlinkat/||/renameat/) &&(/ key= *[:-~]* *$/||/ -k *[:-~]* *$/)" /etc/audit/rules.d/
*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' || printf
"ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```

6.2.3.9 Ensure discretionary access control permission modification events are collected

Info

Monitor changes to file permissions, attributes, ownership and group.

The parameters in this section track changes for system calls that affect file permissions and attributes.

The following commands and system calls effect the permissions, ownership and various attributes of files. - chmod - fchmod - fchmodat - chown - fchown - fchownat - lchown - setxattr - lsetxattr - fsetxattr - removexattr - lremovexattr - fremovexattr In all cases, an audit record will only be written for non-system user ids and will ignore Daemon events.

All audit records will be tagged with the identifier "perm_mod." Monitoring for changes in file attributes could alert a system administrator to activity that could indicate intruder activity or policy violation.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor discretionary access control permission modification events. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F arch=b64 -S chmod,fchmod,fchmodat -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod -a always,exit -F arch=b64 -S chown,fchown,lchown,fchownat -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod -a always,exit -F arch=b32 -S chmod,fchmod,fchmodat -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod -a always,exit -F arch=b32 -S lchown,fchown,chown,fchownat -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod -a always,exit -F arch=b64 -S setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod -a always,exit -F arch=b32 -S setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F auid>=\${UID_MIN} -F auid!=unset -F key=perm_mod " >> /etc/audit/rules.d/50-perm_mod.rules | | printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6
800-53R5	AU-3
800-53R5	CM-6

CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	5.5
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7

ITSG-33	AU-12
ITSG-33	CM-6
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl b32 setxattr
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&( / -F *aud!
```

```

=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/setxattr/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fchownat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -
F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fchownat/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 fchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fchownat/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 chmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chmod/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 chmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chmod/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 lremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/lremovexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 fremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F
*audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/
fremovexattr/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fsetxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fsetxattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```

```

-----
FAILED - auditctl b32 fchmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *auid!
=unset/|/ -F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchmod/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F
*auid!=unset/|/ -F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/
fremovexattr/ &&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 chown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *auid!
=unset/|/ -F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/chown/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fchmodat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *auid!=unset/|/ -
F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchmodat/ &&/ key=
*[-~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fchmodat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *auid!=unset/|/ -
F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchmodat/ &&/ key=
*[-~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fsetxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *auid!
=unset/|/ -F *auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fsetxattr/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fsetxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *auid!=unset/|/ -F
*auid!=-1/|/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fsetxattr/ &&/ key=
*[-~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *auid!

```

```

=unset/||/ -F *aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/fchown/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fchmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/fchmod/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 lremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/lremovexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 fchmodat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *aud!
=unset/||/ -F *aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/fchmodat/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/fchown/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 setxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/setxattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/fremovexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 removexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *aud!=unset/||/ -F
*aud!=1/||/ -F *aud!=4294967295/) &&/ -S/ &&/ -F *aud>=${UID_MIN}/ &&/removexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```

```

-----
FAILED - b32 lchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!=unset/|/ -F
*uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/lchown/ &&/ key= *[-~
~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 lsetxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *uid!
=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/lsetxattr/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 removexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F
*uid!=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/
removexattr/ &&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fchmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *uid!
=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/fchmod/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fchmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *uid!
=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/setxattr/ &&/ key=
*[-~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 setxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!=unset/|/ -
F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/setxattr/ &&/ key=
*[-~]* *$/|/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 fchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!
=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/fchown/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 chown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!
=unset/|/ -F *uid!=-1/|/ -F *uid!=4294967295/) &&/ -S/ &&/ -F *uid>=${UID_MIN}/ &&/chown/
&&/ key= *[-~]* *$/|/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/|/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *uid!=unset/|/ -F

```

```

*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fchown/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 fchmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fchmod/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 chown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chown/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fremovexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 lsetxattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/lsetxattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 removexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/removexattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 chmod
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chmod/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 removexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F
*audit!=unset/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/
removexattr/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print}' END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

```

```

-----
FAILED - auditctl b64 fchmodat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *auid!
=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchmodat/
&&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 lchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *auid!
=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/lchown/
&&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 lchown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&(/ -F *auid!
=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/lchown/
&&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 lremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F
*auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/
lremovexattr/ &&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b32 fchownat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&(/ -F *auid!=unset/||/ -
F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchownat/ &&(/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b64 fchownat
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *auid!
=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/fchownat/
&&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - auditctl b32 lremovexattr
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ]
&& auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&(/ -F
*auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) &&/ -S/ &&/ -F *auid>=${UID_MIN}/ &&/
lremovexattr/ &&(/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :

fail

-----
FAILED - b64 chown
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&(/ -F *auid!=unset/||/ -F

```



```
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chown/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - auditctl b32 fsetxattr

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/fsetxattr/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - b64 lchown

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/lchown/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - auditctl b64 setxattr

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/setxattr/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - auditctl b64 lsetxattr

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/lsetxattr/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0)
print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - b64 chmod

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/chmod/ &&/ key= *[-~]
~]* *$/||/ -k *[-~]* *$/)" /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print
"pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - auditctl b32 lsetxattr

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F *audit!
=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -S/ &&/ -F *audit>=${UID_MIN}/ &&/lsetxattr/
&&/ key= *[-~]* *$/||/ -k *[-~]* *$/)" | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

6.2.1.3 Ensure auditing for processes that start prior to auditd is enabled

Info

Configure grub2 so that processes that are capable of being audited can be audited even if they start up prior to auditd startup. Audit events need to be captured on processes that start up prior to auditd, so that potential malicious activity cannot go undetected.

Solution

Edit /etc/default/grub and add audit=1 to GRUB_CMDLINE_LINUX : Example: GRUB_CMDLINE_LINUX="audit=1"
Run the following command to update the grub2 configuration: # update-grub

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.01
800-171R3	03.03.02a.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-2
800-53	AU-3
800-53	AU-7
800-53	AU-12
800-53R5	AU-2
800-53R5	AU-3
800-53R5	AU-12
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.3(a)
CN-L3	8.1.4.3(b)
CSCV7	6.2
CSCV8	8.2
CSF	DE.CM-1
CSF	DE.CM-3

CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-3
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T3.6.2
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	AM34a
NIAV2	AM34b

NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

The command '/bin/find /boot -type f -name 'grub.cfg' -exec /bin/grep -Ph -- '\^h*linux' {} + | /bin/grep -v 'audit=1' | /bin/awk '{ print } END { if (NR==0) print "pass" }' returned :

```
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240 panic=-1
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240 panic=-1
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro recovery
nomodeset dis_ucode_ldr console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro recovery
nomodeset dis_ucode_ldr console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
panic=-1
```

6.2.3.18 Ensure successful and unsuccessful attempts to use the usermod command are collected

Info

The operating system must generate audit records for successful/unsuccessful uses of the usermod command. The usermod command modifies the system account files to reflect the changes that are specified on the command line.

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter).

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor successful and unsuccessful attempts to use the usermod command. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F path=/usr/sbin/usermod -F perm=x -F auid=\${UID_MIN} -F auid!=unset -k usermod " >> /etc/audit/rules.d/50-usermod.rules || printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CSCV7	6.2
CSCV8	8.2
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1

NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
FAILED - /etc/audit/rules.d/*.rules
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( / -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\/
usr\/sbin\/usermod/ &&( / key= *[:-~]* *$/||/ -k *[:-~]* *$/) " | /bin/awk '{print} END {if (NR !
= 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n "
returned :
```

fail

```
FAILED - auditctl
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( / -F *audit!=unset/||/ -F *audit!=-1/||/ -F
*audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\/usr\/sbin\/usermod/
&&( / key= *[:-~]* *$/||/ -k *[:-~]* *$/) " /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if
(NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n
" returned :
```

fail

6.2.3.1 Ensure changes to system administration scope (sudoers) is collected

Info

Monitor scope changes for system administrators.

If the system has been properly configured to force system administrators to log in as themselves first and then use the sudo command to execute privileged commands, it is possible to monitor changes in scope.

The file /etc/sudoers, or files in /etc/sudoers.d, will be written to when the file(s) or related attributes have changed.

The audit records will be tagged with the identifier "scope". Changes in the /etc/sudoers and /etc/sudoers.d files can indicate that an unauthorized change has been made to the scope of system administrator activity.

Solution

Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor scope changes for system administrators. Example: `# printf " -w /etc/sudoers -p wa -k scope -w /etc/sudoers.d -p wa -k scope " >> /etc/audit/rules.d/50-scope.rules` Merge and load the rules into active configuration: `# augenrules --load` Check if reboot is required. `# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot required to load rules\n"; fi`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	4.8
CSCV8	8.5
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3

PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl /etc/sudoers
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/\etc\sudoers/ &&/ +-p *wa/ &&/ key=
*[*!~]* *$/||/ -k *[*!~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - /etc/sudoers.d
The command '/bin/awk '/^ *-w/ &&/\etc\sudoers.d/ &&/ +-p *wa/ &&/ key= *[*!~]* *$/||/ -k *[*!~]*
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else
print "fail"}' returned :

fail

-----
FAILED - /etc/sudoers
The command '/bin/awk '/^ *-w/ &&/\etc\sudoers/ &&/ +-p *wa/ &&/ key= *[*!~]* *$/||/ -k *[*!~]*
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - auditctl /etc/sudoers.d
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/\etc\sudoers.d/ &&/ +-p *wa/ &&/ key=
*[*!~]* *$/||/ -k *[*!~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail
```

6.2.3.11 Ensure session initiation information is collected

Info

Monitor session initiation events.

The parameters in this section track changes to the files associated with session events. - /var/run/utmp - tracks all currently logged in users. - /var/log/wtmp - file tracks logins, logouts, shutdown, and reboot events. - /var/log/btmp - keeps track of failed login attempts and can be read by entering the command /usr/bin/last -f /var/log/btmp. All audit records will be tagged with the identifier "session." Monitoring these files for changes could alert a system administrator to logins occurring at unusual hours, which could indicate intruder activity (i.e. a user logging in at a time when they do not normally log in).

Solution

Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor session initiation information. Example: # printf " -w /var/run/utmp -p wa -k session -w /var/log/wtmp -p wa -k session -w /var/log/btmp -p wa -k session " >> /etc/audit/rules.d/50-session.rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	4.9
CSCV7	16.13
CSCV8	8.5

CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1

PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl utmp
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/\var/run/utmp/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - utmp
The command '/bin/awk '/^ *-w/ &&/\var/run/utmp/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k
*[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' returned :

fail

-----
FAILED - btmp
The command '/bin/awk '/^ *-w/ &&/\var/log/btmp/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k
*[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}' returned :

fail

-----
FAILED - auditctl wtmp
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/\var/log/wtmp/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - auditctl btmp
```

```
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/\var/log/btmp/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}'' returned :
```

fail

FAILED - wtmp

```
The command '/bin/awk '/^ *-w/ &&/\var/log/wtmp/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k
*[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;
else print "fail"}'' returned :
```

fail

6.2.3.16 Ensure successful and unsuccessful attempts to use the setfacl command are collected

Info

The operating system must generate audit records for successful/unsuccessful uses of the setfacl command. This utility sets Access Control Lists (ACLs) of files and directories. Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter).

Solution

Create audit rules. Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor successful and unsuccessful attempts to use the setfacl command. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F path=/usr/bin/setfacl -F perm=x -F auid>=\${UID_MIN} -F auid!=unset -k perm_chng " >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CSCV7	6.2
CSCV8	8.2
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1

NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
FAILED - /etc/audit/rules.d/*.rules
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\\
usr\\bin\\setfacl/ &&( key= *[-~]* *$/||/ -k *[-~]* *$/) " | /bin/awk '{print} END {if (NR !
= 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n "
returned :
```

fail

```
FAILED - auditctl
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( -F *audit!=unset/||/ -F *audit!=-1/||/ -F
*audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\\usr\\bin\\setfacl/
&&( key= *[-~]* *$/||/ -k *[-~]* *$/) " /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if
(NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n
" returned :
```

fail

6.2.3.15 Ensure successful and unsuccessful attempts to use the chcon command are collected

Info

The operating system must generate audit records for successful/unsuccessful uses of the chcon command. The chcon command is used to change file security context. Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter).

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor successful and unsuccessful attempts to use the chcon command. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F path=/usr/bin/chcon -F perm=x -F auid>=\${UID_MIN} -F auid!=unset -k perm_chng " >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CSCV7	6.2
CSCV8	8.2
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1

NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - /etc/audit/rules.d/*.rules
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( /-F *audit!=unset/||/ -F *audit!=-1/||/ -
F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\usr\bin\chcon/
&&( /key= *[-~]* *$/||/ -k *[-~]* *$/) " /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if
(NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n "
returned :
```

fail

```
-----
FAILED - auditctl
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&( /-F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=
\usr\bin\chcon/ &&( /key= *[-~]* *$/||/ -k *[-~]* *$/) " | /bin/awk '{print} END {if (NR !
= 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n "
returned :
```

fail

3.2.4 Ensure sctp kernel module is not available

Info

The Stream Control Transmission Protocol (SCTP) is a transport layer protocol used to support message oriented communication, with several streams of messages in one connection. It serves a similar function as TCP and UDP, incorporating features of both. It is message-oriented like UDP, and ensures reliable in-sequence transport of messages with congestion control like TCP. - IF - the protocol is not being used, it is recommended that kernel module not be loaded, disabling the service to reduce the potential attack surface.

Solution

Run the following script to unload and disable the sctp module: - IF - the sctp kernel module is available in ANY installed kernel: - Create a file ending in .conf with install sctp /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist sctp in the /etc/modprobe.d/ directory - Run modprobe -r sctp 2>/dev/null; rmmod sctp 2>/dev/null to remove sctp from the kernel - IF - the sctp kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary #!/usr/bin/env bash { a_output2=() a_output3=() l_dl="" l_mod_name="sctp" l_mod_type="net" l_mod_path="\$(readlink -f /lib/modules/**/kernel/\${l_mod_name} | sort -u)" f_module_fix() { l_dl="y" a_showconfig=() while IFS= read -r l_showconfig; do a_showconfig+="\${l_showconfig}" done < <(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+""\${l_mod_chk_name}/-/_"\b') if lsmod | grep "\${l_mod_chk_name}" && /dev/null; then a_output2+=(" - unloading kernel module: \"\${l_mod_name}\"") modprobe -r "\${l_mod_chk_name}" 2>/dev/null; rmmod "\${l_mod_name}" 2>/dev/null if ! grep -Pq -- '\binstall\h+""\${l_mod_chk_name}/-/_"\b' <<< "\${a_showconfig[*]}"; then a_output2+=(" - setting kernel module: \"\${l_mod_name}\" to \"\$(readlink -f /bin/false)\"") printf '%s\n' "install \${l_mod_chk_name} \$(readlink -f /bin/false)" >> /etc/modprobe.d/"\${l_mod_name}.conf" if ! grep -Pq -- '\bblacklist\h+""\${l_mod_chk_name}/-/_"\b' <<< "\${a_showconfig[*]}"; then a_output2+=(" - denylisting kernel module: \"\${l_mod_name}\"") printf '%s\n' "blacklist \${l_mod_chk_name}" >> /etc/modprobe.d/"\${l_mod_name}.conf" fi } for l_mod_base_directory in \${l_mod_name}/-/_"] && [-n "\$(ls -A "\${l_mod_base_directory}/\${l_mod_name}/-/_")"]; then a_output3+=(" - \"\${l_mod_base_directory}\" l_mod_chk_name=\"\${l_mod_name}\" ["\${l_mod_name}" =~ overlay] && l_mod_chk_name="\${l_mod_name}:-2)" ["\${l_dl}" != "y"] && f_module_fix else printf '%s\n' " - kernel module: \"\${l_mod_name}\" doesn't exist in \"\${l_mod_base_directory}\"" fi done ["\${#a_output3[@]}" -gt 0] && printf '%s\n' "" -- INFO -- " - module: \"\${l_mod_name}\" exists in: " "\${a_output3[@]}" ["\${#a_output2[@]}" -gt 0] && printf '%s\n' "" "\${a_output2[@]}" | | printf '%s\n' "" " - No changes needed" printf '%s\n' "" " - remediation of kernel module: \"\${l_mod_name}\" complete" "" }

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.14.6
800-171	3.14.7
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.14.06
800-53	CM-6
800-53	CM-7
800-53	SI-4
800-53R5	CM-7

800-53R5	SI-4
CN-L3	7.1.3.5(a)
CN-L3	8.1.10.5(b)
CN-L3	8.1.10.6(f)
CSCV7	9.2
CSCV8	4.8
CSF	DE.AE-1
CSF	DE.AE-2
CSF	DE.AE-3
CSF	DE.AE-4
CSF	DE.CM-1
CSF	DE.CM-5
CSF	DE.CM-6
CSF	DE.CM-7
CSF	DE.DP-2
CSF	DE.DP-3
CSF	DE.DP-4
CSF	DE.DP-5
CSF	ID.RA-1
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.IP-8
CSF	PR.PT-3
CSF	RS.AN-1
CSF	RS.CO-3
CSF2.0	DE.AE-02
CSF2.0	DE.AE-03
CSF2.0	DE.CM-01
CSF2.0	DE.CM-06
CSF2.0	DE.CM-09
CSF2.0	ID.IM-01

CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	ID.RA-01
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.16
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	SI-4
LEVEL	2A
NESA	M1.2.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	5.2.3
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
-- INFO --
- module: "sctp" exists in:
  - "/usr/lib/modules/6.17.0-1018-azure/kernel/net"
```

- Audit Result:
 - ** FAIL **
- Reason(s) for audit failure:
 - kernel module: "sctp" is loadable
 - kernel module: "sctp" is not deny listed
- Correctly set:
 - kernel module: "sctp" is not loaded

6.2.3.17 Ensure successful and unsuccessful attempts to use the chacl command are collected

Info

The operating system must generate audit records for successful/unsuccessful uses of the chacl command. chacl is an IRIX-compatibility command, and is maintained for those users who are familiar with its use from either XFS or IRIX. chacl changes the ACL(s) for a file or directory.

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter).

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor successful and unsuccessful attempts to use the chacl command. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F path=/usr/bin/chacl -F perm=x -F auid>=\${UID_MIN} -F auid!=unset -k perm_chng " >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CSCV7	6.2
CSCV8	8.2
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1

NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - /etc/audit/rules.d/*.rules
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&(/ -F *audit!=unset/||/ -F *audit!=-1/||/ -
F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=\usr\bin\chac\
&&(/ key= *[-~]* *$/||/ -k *[-~]* *$/) " /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if
(NR != 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n
" returned :
```

fail

```
-----
FAILED - auditctl
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk "(/^ *-a *always,exit/||/^ *-a *exit,always/) &&(/ -F *audit!=unset/||/ -F
*audit!=-1/||/ -F *audit!=4294967295/) &&/ -F *audit>=${UID_MIN}/ &&/ -F *perm=x/ &&/ -F *path=
\usr\bin\chac\ &&(/ key= *[-~]* *$/||/ -k *[-~]* *$/) " | /bin/awk '{print} END {if (NR !
= 0) print "pass" ; else print "fail"}' || printf "ERROR: Variable 'UID_MIN' is unset. \n "
returned :
```

fail

6.2.2.1 Ensure audit log storage size is configured

Info

Configure the maximum size of the audit log file.

Once the log reaches the maximum size, it will be rotated and a new log file will be started. It is important that an appropriate size is determined for log files so that they do not impact the system and audit data is not lost.

Solution

Set the following parameter in `/etc/audit/auditd.conf` in accordance with site policy: `max_log_file = <MB>`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.7
800-171R3	03.03.07
800-53	AU-4
800-53	AU-8
800-53R5	AU-8
CN-L3	8.1.4.3(b)
CSCV7	6.4
CSCV8	8.3
CSF	PR.DS-4
CSF	PR.PT-1
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ISO-27001-2022	A.8.17
ITSG-33	AU-4
ITSG-33	AU-8
LEVEL	2A
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
TBA-FIISB	37.4

Assets

abel-ubuntu-server

Non-compliant file(s):

```
/etc/audit/auditd.conf - regex '^[\\s]*max_log_file[\\s]*=' found - expect  
'^[\\s]*max_log_file[\\s]*=[\\s]*32[\\s]*$' not found in the following lines:  
    12: max_log_file = 10
```

1.1.2.5.1 Ensure separate partition exists for /var/tmp

Info

The /var/tmp directory is a world-writable directory used for temporary storage by all users and some applications.

Temporary files residing in /var/tmp are to be preserved between reboots. The default installation only creates a single / partition.

Since the /var/tmp directory is world-writable, there is a risk of resource exhaustion.

In addition, other operations on the system could fill up the disk unrelated to /var/tmp and cause potential disruption to daemons as the disk is full. Configuring /var/tmp as its own file system allows an administrator to set additional mount options such as noexec/nosuid/nODEV.

These options limit an attacker's ability to create exploits on the system.

Solution

For new installations, during installation create a custom partition setup and specify a separate partition for /var/tmp. For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate. Impact: Resizing filesystems is a common activity in cloud-hosted servers.

Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations.

The use of these additional tools may introduce their own security considerations.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.4.6
800-171	3.4.7
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.04.06
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	CM-7
800-53	MP-2
800-53R5	CM-7

CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3

ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	CM-7
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15a
NIAV2	SS15c

NIAV2	SS29
PCI-DSSV3.2.1	2.2.2
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	5.1
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

The following file(s) do not contain "[\s]+/var/tmp[\s]+":
 /proc/self/mountinfo

6.2.2.4 Ensure system warns when audit logs are low on space

Info

The auditd daemon can be configured to halt the system, put the system in single user mode or send a warning message, if the partition that holds the audit log files is low on space. The `space_left_action` parameter tells the system what action to take when the system has detected that it is starting to get low on disk space. Valid values are ignore, syslog, rotate, email, exec, suspend, single, and halt. - ignore, the audit daemon does nothing - syslog, the audit daemon will issue a warning to syslog - rotate, the audit daemon will rotate logs, losing the oldest to free up space - email, the audit daemon will send a warning to the email account specified in `action_mail_acct` as well as sending the message to syslog - exec, /path-to-script will execute the script. You cannot pass parameters to the script.

The script is also responsible for telling the auditd daemon to resume logging once its completed its action - suspend, the audit daemon will stop writing records to the disk - single, the audit daemon will put the computer system in single user mode - halt, the audit daemon will shut down the system The `admin_space_left_action` parameter tells the system what action to take when the system has detected that it is low on disk space.

Valid values are ignore, syslog, rotate, email, exec, suspend, single, and halt. - ignore, the audit daemon does nothing - syslog, the audit daemon will issue a warning to syslog - rotate, the audit daemon will rotate logs, losing the oldest to free up space - email, the audit daemon will send a warning to the email account specified in `action_mail_acct` as well as sending the message to syslog - exec, /path-to-script will execute the script. You cannot pass parameters to the script.

The script is also responsible for telling the auditd daemon to resume logging once its completed its action - suspend, the audit daemon will stop writing records to the disk - single, the audit daemon will put the computer system in single user mode - halt, the audit daemon will shut down the system In high security contexts, the risk of detecting unauthorized access or nonrepudiation exceeds the benefit of the system's availability.

Solution

Set the `space_left_action` parameter in `/etc/audit/auditd.conf` to email, exec, single, or halt : Example: `space_left_action = email` Set the `admin_space_left_action` parameter in `/etc/audit/auditd.conf` to single or halt : Example: `admin_space_left_action = single` Note: A Mail Transfer Agent (MTA) must be installed and configured properly to set `space_left_action = email` Impact: If the `admin_space_left_action` is set to single the audit daemon will put the computer system in single user mode.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.3.7
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.03.07
800-171R3	03.14.03
800-53	AU-2
800-53	AU-4
800-53	AU-7

800-53	AU-8
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-8
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CN-L3	8.1.4.3(b)
CSCV7	6.2
CSCV8	8.2
CSCV8	8.3
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.DS-4
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03

CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.17
ITSG-33	AU-2
ITSG-33	AU-4
ITSG-33	AU-7
ITSG-33	AU-8
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T3.3.1
NESA	T3.6.2
NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1

QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4
TBA-FIISB	37.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - admin_space_left_action
Non-compliant file(s):
/etc/audit/auditd.conf - regex '(?i)^\s*admin_space_left_action\s*=' found - expect '(?i)^\s*admin_space_left_action\s*=[\s]*(single|halt)\s*$' not found in the following lines:
23: admin_space_left_action = SUSPEND
```

```
-----
FAILED - space_left_action
Non-compliant file(s):
/etc/audit/auditd.conf - regex '(?i)^\s*space_left_action\s*=' found - expect '(?i)^\s*space_left_action\s*=[\s]*(email|exec|single|halt)\s*$' not found in the following lines:
19: space_left_action = SYSLOG
```

6.2.3.8 Ensure events that modify user/group information are collected

Info

Record events affecting the modification of user or group information, including that of passwords and old passwords if in use. - /etc/group - system groups - /etc/passwd - system users - /etc/gshadow - encrypted password for each group - /etc/shadow - system user passwords - /etc/security/opasswd - storage of old passwords if the relevant PAM module is in use - /etc/nsswitch.conf - file configures how the system uses various databases and name resolution mechanisms - /etc/pam.conf - file determines the authentication services to be used, and the order in which the services are used. - /etc/pam.d - directory contains the PAM configuration files for each PAM-aware application. The parameters in this section will watch the files to see if they have been opened for write or have had attribute changes (e.g. permissions) and tag them with the identifier "identity" in the audit log file. Unexpected changes to these files could be an indication that the system has been compromised and that an unauthorized user is attempting to hide their activities or compromise additional accounts.

Solution

Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor events that modify user/group information. Example: # printf " -w /etc/group -p wa -k identity -w /etc/passwd -p wa -k identity -w /etc/gshadow -p wa -k identity -w /etc/shadow -p wa -k identity -w /etc/security/opasswd -p wa -k identity -w /etc/nsswitch.conf -p wa -k identity -w /etc/pam.conf -p wa -k identity -w /etc/pam.d -p wa -k identity " >> /etc/audit/rules.d/50-identity.rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)

CSCV7	4.8
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f

NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - /etc/shadow
The command '/bin/awk '/^ *-w/ &&/etc/shadow/ &&/ +-p *wa/ &&/ key= *[:-~]* *$/||/ -k *[:-~]*
*$)/' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :
```

fail

```
-----
FAILED - auditctl /etc/nsswitch.conf
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/nsswitch.conf/ &&/ +-p *wa/ &&/
key= *[:-~]* *$/||/ -k *[:-~]* *$)/' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else
print "fail"}' returned :
```

fail

```
-----
FAILED - /etc/pam.conf
The command '/bin/awk '/^ *-w/ &&/etc/pam.conf/ &&/ +-p *wa/ &&/ key= *[:-~]* *$/||/ -k *[:-~]*
*$)/' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else
print "fail"}' returned :
```

fail

```
-----
FAILED - /etc/gshadow
The command '/bin/awk '/^ *-w/ &&/etc/gshadow/ &&/ +-p *wa/ &&/ key= *[:-~]* *$/||/ -k *[:-~]*
*$)/' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else
print "fail"}' returned :
```


fail

```
-----  
FAILED - auditctl /etc/security/opasswd  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/security/opasswd/ &&/ +-p *wa/ &&/  
key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else  
print "fail"}' returned :
```

fail

```
-----  
FAILED - /etc/group  
The command '/bin/awk '/^ *-w/ &&/etc/group/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*  
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - /etc/passwd  
The command '/bin/awk '/^ *-w/ &&/etc/passwd/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*  
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - auditctl /etc/pam.d  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/pam.d/ &&/ +-p *wa/ &&/ key=  
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - auditctl /etc/shadow  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/shadow/ &&/ +-p *wa/ &&/ key=  
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - auditctl /etc/gshadow  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/gshadow/ &&/ +-p *wa/ &&/ key=  
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - /etc/nsswitch.conf  
The command '/bin/awk '/^ *-w/ &&/etc/nsswitch.conf/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -  
k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;  
else print "fail"}' returned :
```

fail

```
-----  
FAILED - auditctl /etc/passwd  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/passwd/ &&/ +-p *wa/ &&/ key=  
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - /etc/security/opasswd  
The command '/bin/awk '/^ *-w/ &&/etc/security/opasswd/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/  
-k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;  
else print "fail"}' returned :
```

fail

```
FAILED - /etc/pam.d
The command '/bin/awk '/^ *-w/ &&/etc/pam.d/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*
*$)/' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}'' returned :
```

fail

```
FAILED - auditctl /etc/group
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/group/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$)/' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}'' returned :
```

fail

```
FAILED - auditctl /etc/pam.conf
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/pam.conf/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$)/' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}'' returned :
```

fail

5.4.1.2 Ensure minimum password days is configured

Info

PASS_MIN_DAYS < N > - The minimum number of days allowed between password changes.

Any password changes attempted sooner than this will be rejected.

If not specified, 0 will be assumed (which disables the restriction). Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise.

Unfortunately, passwords are compromised and if an attacker is targeting a specific individual user account, with foreknowledge of data about that user, reuse of old, potentially compromised passwords, may cause a security breach. By restricting the frequency of password changes, an administrator can prevent users from repeatedly changing their password in an attempt to circumvent password reuse controls

Solution

Edit /etc/login.defs and set PASS_MIN_DAYS to a value greater than 0 that follows local site policy: Example:

PASS_MIN_DAYS 1 Run the following command to modify user parameters for all users with a password set to a minimum days greater than zero that follows local site policy: # chage --mindays <N> <user> Example: # awk -F: '(\$2~/^\\$.\+\\\$/) {if(\$4 < 1)system ("chage --mindays 1 " \$1)}' /etc/shadow Impact: If a users password is set by other personnel as a procedure in dealing with a lost or expired password, the user should be forced to update this "set" password with their own password.

e.g.

force "change at next logon". If it is not possible to have a user set their own password immediately, and this recommendation or local site procedure may cause a user to continue using a third party generated password, PASS_MIN_DAYS for the effected user should be temporally changed to 0, to allow a user to change their password immediately. For applications where the user is not using the password at console, the ability to "change at next logon" may be limited.

This may cause a user to continue to use a password created by other personnel.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.5.2
800-171R3	03.05.07
800-53	IA-5(1)
800-53R5	IA-5(1)
CSCV7	4.4
CSCV8	5.2
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(1)

LEVEL	2M
NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2
SWIFT-CSCV1	4.1

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

FAILED - shadow password min days

The command '/bin/awk -F: '(\$2~/^\\$.+\/) {if(\$4 < 1)print "User: " \$1 " PASS_MIN_DAYS: " \$4}' /etc/shadow | /bin/awk '{print} END {if (NR == 0) print "pass"; else print "fail"}}' returned :

User: lababel PASS_MIN_DAYS: 0

fail

FAILED - login.defs - PASS_MIN_DAYS

Non-compliant file(s):

/etc/login.defs - regex '(?i)^\h*PASS_MIN_DAYS\h+\d+\b' found - expect '(?i)^\h*PASS_MIN_DAYS\h+1\b' not found in the following lines:
166: PASS_MIN_DAYS 0

6.2.3.2 Ensure actions as another user are always logged

Info

sudo provides users with temporary elevated privileges to perform operations, either as the superuser or another user. Creating an audit log of users with temporary elevated privileges and the operation(s) they performed is essential to reporting.

Administrators will want to correlate the events written to the audit trail with the records written to sudo's logfile to verify if unauthorized commands have been executed.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor elevated privileges. Example: # printf " -a always,exit -F arch=b64 -C euid!=uid -F auid!=unset -S execve -k user_emulation -a always,exit -F arch=b32 -C euid!=uid -F auid!=unset -S execve -k user_emulation " >> /etc/audit/rules.d/50-user_emulation.rules Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	4.9
CSCV8	8.5
CSF	DE.CM-1

CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3

PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - /etc/audit/rules.d/*.rules b32
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -F
*audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -C *euid!=uid/||/ -C *uid!=euid/)
&&/ -S *execve/ &&/ key= *[*!~]* *$/||/ -k *[*!~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----
FAILED - /etc/audit/rules.d/*.rules b64
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -F
*audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -C *euid!=uid/||/ -C *uid!=euid/)
&&/ -S *execve/ &&/ key= *[*!~]* *$/||/ -k *[*!~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----
FAILED - auditctl b64
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -
F *arch=b64/ &&/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -C *euid!
=uid/||/ -C *uid!=euid/) &&/ -S *execve/ &&/ key= *[*!~]* *$/||/ -k *[*!~]* *$/)' | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----
FAILED - auditctl b32
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -
F *arch=b32/ &&/ -F *audit!=unset/||/ -F *audit!=-1/||/ -F *audit!=4294967295/) &&/ -C *euid!
=uid/||/ -C *uid!=euid/) &&/ -S *execve/ &&/ key= *[*!~]* *$/||/ -k *[*!~]* *$/)' | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

1.3.1.4 Ensure all AppArmor Profiles are enforcing

Info

AppArmor profiles define what resources applications are able to access. Security configuration requirements vary from site to site.

Some sites may mandate a policy that is stricter than the default policy, which is perfectly acceptable.

This item is intended to ensure that any policies that exist on the system are activated.

Solution

Run the following command to set all profiles to enforce mode: `# aa-enforce /etc/apparmor.d/*` Note: Any unconfined processes may need to have a profile created or activated for them and then be restarted

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	MP-2
800-53R5	AC-3
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1

CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	MP-2
ITSG-33	MP-2a.

LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	13.2
SWIFT-CSCV1	5.1
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

PASSED - apparmor_status - processes are confined
The command '/sbin/apparmor_status' returned :

```
apparmor module is loaded.
118 profiles are loaded.
24 profiles are in enforce mode.
   /usr/bin/man
   /usr/lib/snapd/snap-confine
   /usr/sbin/chronyd
   lsb_release
   man_filter
   man_groff
   nvidia_modprobe
   nvidia_modprobe//kmod
   plasmashell
   plasmashell//QtWebEngineProcess
   rsyslogd
   tcpdump
   ubuntu_pro_apt_news
   ubuntu_pro_esm_cache
   ubuntu_pro_esm_cache//apt_methods
   ubuntu_pro_esm_cache//apt_methods_gpgv
   ubuntu_pro_esm_cache//cloud_id
   ubuntu_pro_esm_cache//dpkg
   ubuntu_pro_esm_cache//ps
   ubuntu_pro_esm_cache//ubuntu_distro_info
   ubuntu_pro_esm_cache_systemctl
   ubuntu_pro_esm_cache_systemd_detect_virt
   unix-chkpwd
   unprivileged_usersns
4 profiles are in complain mode.
   transmission-cli
   transmission-daemon
   transmission-gtk
   transmission-qt
0 profiles are in prompt mode.
0 profiles are in kill mode.
90 profiles are in unconfined mode.
   1password
   Discord
   MongoDB Compass
   QtWebEngineProcess
   balena-etcher
   brave
   buildah
   cam
   ch-checkns
   ch-run
   chrome
   crun
   devhelp
   element-desktop
   epiphany
   evolution
   firefox
   flatpak
   foliate
   geary
   github-desktop
   goldendict
   ipa_verify
   kchmviewer
   keybase
   lc-compliance
   libcamerify
   linux-sandbox
   loupe
   lxc-attach
   lxc-create
   lxc-destroy
   lxc-execute
```

```

lxc-stop
lxc-unshare
lxc-usernsexec
mmdebstrap
msedge
nautilus
notepadqq
obsidian
opam
opera
pageedit
podman
polypane
privacybrowser
qcam
qmapshack
qutebrowser
rootlesskit
rpm
rssguard
runc
sbuid
sbuid-abort
sbuid-adduser
sbuid-apt
sbuid-checkpackages
sbuid-clean
sbuid-createrepo
sbuid-destroyrepo
sbuid-distupgrade
sbuid-hold
sbuid-shell
sbuid-unhold
sbuid-update
sbuid-upgrade
scide
signal-desktop
slack
slirp4netns
steam
stress-ng
surfshark
systemd-coredump
thunderbird
toybox
trinity
tup
tuxedo-control-center
userbindmount
uwsgi-core
vden
virtiofsd
vivaldi-bin
vpns
vscodium
wike
wpcam
3 processes have profiles defined.
3 processes are in enforce mode.
  /usr/sbin/chronyd (860)
  /usr/sbin/chronyd (870)
  /usr/sbin/rsyslogd (6677) rsyslogd
0 processes are in complain mode.
0 processes are in prompt mode.
0 processes are in kill mode.
0 processes are unconfined but have a profile defined.
0 processes are in mixed mode.

-----
PASSED - apparmor_status - profiles are loaded
The command '/sbin/apparmor_status' returned :

apparmor module is loaded.
118 profiles are loaded.
24 profiles are in enforce mode.

```

```

/usr/bin/man
/usr/lib/snapd/snap-confine
/usr/sbin/chronyd
lsb_release
man_filter
man_groff
nvidia_modprobe
nvidia_modprobe//kmod
plasmashell
plasmashell//QtWebEngineProcess
rsyslogd
tcpdump
ubuntu_pro_apt_news
ubuntu_pro_esm_cache
ubuntu_pro_esm_cache//apt_methods
ubuntu_pro_esm_cache//apt_methods_gpgv
ubuntu_pro_esm_cache//cloud_id
ubuntu_pro_esm_cache//dpkg
ubuntu_pro_esm_cache//ps
ubuntu_pro_esm_cache/ubuntu_distro_info
ubuntu_pro_esm_cache_systemctl
ubuntu_pro_esm_cache_systemd_detect_virt
unix-chkpwd
unprivileged_usersns
4 profiles are in complain mode.
  transmission-cli
  transmission-daemon
  transmission-gtk
  transmission-qt
0 profiles are in prompt mode.
0 profiles are in kill mode.
90 profiles are in unconfined mode.
  1password
  Discord
  MongoDB Compass
  QtWebEngineProcess
  balena-etcher
  brave
  buildah
  cam
  ch-checkns
  ch-run
  chrome
  crun
  devhelp
  element-desktop
  epiphany
  evolution
  firefox
  flatpak
  foliate
  geary
  github-desktop
  goldendict
  ipa_verify
  kchmviewer
  keybase
  lc-compliance
  libcamerify
  linux-sandbox
  loupe
  lxc-attach
  lxc-create
  lxc-destroy
  lxc-execute
  lxc-stop
  lxc-unshare
  lxc-usernsexec
  mmdebstrap
  msedge
  nautilus
  notepadqq
  obsidian
  opam
  opera

```

```

pageedit
podman
polypane
privacybrowser
qcam
qmapshack
qutebrowser
rootlesskit
rpm
rssguard
runc
sbuid
sbuid-abort
sbuid-adduser
sbuid-apt
sbuid-checkpackages
sbuid-clean
sbuid-createrepo
sbuid-destroyrepo
sbuid-distupgrade
sbuid-hold
sbuid-shell
sbuid-unhold
sbuid-update
sbuid-upgrade
scide
signal-desktop
slack
slirp4netns
steam
stress-ng
surfshark
systemd-coredump
thunderbird
toybox
trinity
tup
tuxedo-control-center
userbindmount
uwsgi-core
vdens
virtiofsd
vivaldi-bin
vpnn
vscod
wike
wpc
3 processes have profiles defined.
3 processes are in enforce mode.
  /usr/sbin/chronyd (860)
  /usr/sbin/chronyd (870)
  /usr/sbin/rsyslogd (6677) rsyslogd
0 processes are in complain mode.
0 processes are in prompt mode.
0 processes are in kill mode.
0 processes are unconfined but have a profile defined.
0 processes are in mixed mode.

-----
FAILED - apparmor_status - profiles in complain mode
The command '/sbin/apparmor_status' returned :

apparmor module is loaded.
118 profiles are loaded.
24 profiles are in enforce mode.
  /usr/bin/man
  /usr/lib/snapd/snap-confine
  /usr/sbin/chronyd
  lsb_release
  man_filter
  man_groff
  nvidia_modprobe
  nvidia_modprobe//kmod
  plasmashell
  plasmashell//QtWebEngineProcess

```

```

rsyslogd
tcpdump
ubuntu_pro_apt_news
ubuntu_pro_esm_cache
ubuntu_pro_esm_cache//apt_methods
ubuntu_pro_esm_cache//apt_methods_gpgv
ubuntu_pro_esm_cache//cloud_id
ubuntu_pro_esm_cache//dpkg
ubuntu_pro_esm_cache//ps
ubuntu_pro_esm_cache//ubuntu_distro_info
ubuntu_pro_esm_cache_systemctl
ubuntu_pro_esm_cache_systemd_detect_virt
unix-chkpwd
unprivileged_usersns
4 profiles are in complain mode.
  transmission-cli
  transmission-daemon
  transmission-gtk
  transmission-qt
0 profiles are in prompt mode.
0 profiles are in kill mode.
90 profiles are in unconfined mode.
  1password
  Discord
  MongoDB Compass
  QtWebEngineProcess
  balena-etcher
  brave
  buildah
  cam
  ch-checkns
  ch-run
  chrome
  crun
  devhelp
  element-desktop
  epiphany
  evolution
  firefox
  flatpak
  foliate
  geary
  github-desktop
  goldendict
  ipa_verify
  kchmviewer
  keybase
  lc-compliance
  libcamerify
  linux-sandbox
  loupe
  lxc-attach
  lxc-create
  lxc-destroy
  lxc-execute
  lxc-stop
  lxc-unshare
  lxc-usernsexec
  mmdebstrap
  msedge
  nautilus
  notepadqq
  obsidian
  opam
  opera
  pageedit
  podman
  polypane
  privacybrowser
  qcam
  qmapshack
  qutebrowser
  rootlesskit
  rpm
  rssguard

```

```
runc
sbuid
sbuid-abort
sbuid-adduser
sbuid-apt
sbuid-checkpackages
sbuid-clean
sbuid-creatchroot
sbuid-destroychroot
sbuid-distupgrade
sbuid-hold
sbuid-shell
sbuid-unhold
sbuid-update
sbuid-upgrade
scide
signal-desktop
slack
slirp4netns
steam
stress-ng
surfshark
systemd-coredump
thunderbird
toybox
trinity
tup
tuxedo-control-center
userbindmount
uwsgi-core
vden
virtiofsd
vivaldi-bin
vpnn
vscod
wike
wpcod
3 processes have profiles defined.
3 processes are in enforce mode.
  /usr/sbin/chronyd (860)
  /usr/sbin/chronyd (870)
  /usr/sbin/rsyslogd (6677) rsyslogd
0 processes are in complain mode.
0 processes are in prompt mode.
0 processes are in kill mode.
0 processes are unconfined but have a profile defined.
0 processes are in mixed mode.
```


1.1.2.6.1 Ensure separate partition exists for /var/log

Info

The /var/log directory is used by system services to store log data. The default installation only creates a single / partition.

Since the /var/log directory contains log files which can grow quite large, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system as a whole. Configuring /var/log as its own file system allows an administrator to set additional mount options such as noexec/nosuid/noddev.

These options limit an attackers ability to create exploits on the system.

Other options allow for specific behavior.

See man mount for exact details regarding filesystem-independent and filesystem-specific options. As /var/log contains log files, care should be taken to ensure the security and integrity of the data and mount point.

Solution

For new installations, during installation create a custom partition setup and specify a separate partition for /var/log. For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate. Impact: Resizing filesystems is a common activity in cloud-hosted servers.

Separate filesystem partitions may prevent successful resizing, or may require the installation of additional tools solely for the purpose of resizing operations.

The use of these additional tools may introduce their own security considerations.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06
800-53	AU-4
800-53	CM-7
800-53R5	CM-7
CSCV7	6.4
CSCV8	8.3
CSF	PR.DS-4
CSF	PR.IP-1
CSF	PR.PT-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
ITSG-33	CM-7

LEVEL	2A
NESA	T3.3.1
NESA	T3.6.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The following file(s) do not contain "[\s]+/var/log[\s]+":
 /proc/self/mountinfo

6.2.3.12 Ensure login and logout events are collected

Info

Monitor login and logout events.

The parameters below track changes to files associated with login/logout events. - /var/log/lastlog - maintain records of the last time a user successfully logged in. - /var/run/faillock - directory maintains records of login failures via the pam_faillock module. Monitoring login/logout events could provide a system administrator with information associated with brute force attacks against user logins.

Solution

Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor login and logout events. Example: # printf " -w /var/log/lastlog -p wa -k logins -w /var/run/faillock -p wa -k logins " >> /etc/audit/rules.d/50-login.rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	4.9
CSCV7	16.11
CSCV7	16.13

CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g

PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

FAILED - faillock

The command '/bin/awk '/^ *-w/ && /\var/run/faillock/ && +-p *wa/ &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

FAILED - auditctl lastlog

The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ && /\var/log/lastlog/ && +-p *wa/ &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

FAILED - auditctl faillock

The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ && /\var/run/faillock/ && +-p *wa/ &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

FAILED - lastlog

The command '/bin/awk '/^ *-w/ && /\var/log/lastlog/ && +-p *wa/ &&/ key= *[-~]* *\$/||/ -k *[-~]* *\$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

6.2.2.3 Ensure system is disabled when audit logs are full

Info

The auditd daemon can be configured to halt the system or put the system in single user mode, if no free space is available or an error is detected on the partition that holds the audit log files. The disk_full_action parameter tells the system what action to take when no free space is available on the partition that holds the audit log files.

Valid values are ignore, syslog, rotate, exec, suspend, single, and halt. - ignore, the audit daemon will issue a syslog message but no other action is taken - syslog, the audit daemon will issue a warning to syslog - rotate, the audit daemon will rotate logs, losing the oldest to free up space - exec, /path-to-script will execute the script.

You cannot pass parameters to the script.

The script is also responsible for telling the auditd daemon to resume logging once its completed its action - suspend, the audit daemon will stop writing records to the disk - single, the audit daemon will put the computer system in single user mode - halt, the audit daemon will shut down the system The disk_error_action parameter tells the system what action to take when an error is detected on the partition that holds the audit log files.

Valid values are ignore, syslog, exec, suspend, single, and halt. - ignore, the audit daemon will not take any action - syslog, the audit daemon will issue no more than 5 consecutive warnings to syslog - exec, /path-to-script will execute the script.

You cannot pass parameters to the script - suspend, the audit daemon will stop writing records to the disk - single, the audit daemon will put the computer system in single user mode - halt, the audit daemon will shut down the system In high security contexts, the risk of detecting unauthorized access or nonrepudiation exceeds the benefit of the system's availability.

Solution

Set one of the following parameters in /etc/audit/auditd.conf depending on your local security policies.

disk_full_action = <halt|single> disk_error_action = <syslog|single|halt> Example: disk_full_action = halt

disk_error_action = halt Impact: disk_full_action parameter: - Set to halt - the auditd daemon will shutdown

the system when the disk partition containing the audit logs becomes full. - Set to single - the auditd daemon

will put the computer system in single user mode when the disk partition containing the audit logs becomes

full. disk_error_action parameter: - Set to halt - the auditd daemon will shutdown the system when an error is

detected on the partition that holds the audit log files. - Set to single - the auditd daemon will put the computer

system in single user mode when an error is detected on the partition that holds the audit log files. - Set to

syslog - the auditd daemon will issue no more than 5 consecutive warnings to syslog when an error is detected on the partition that holds the audit log files.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.3.7
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.03.07
800-171R3	03.14.03
800-53	AU-2
800-53	AU-4

800-53	AU-7
800-53	AU-8
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-8
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CN-L3	8.1.4.3(b)
CSCV8	8.2
CSCV8	8.3
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.DS-4
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03

CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.17
ITSG-33	AU-2
ITSG-33	AU-4
ITSG-33	AU-7
ITSG-33	AU-8
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T3.3.1
NESA	T3.6.2
NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1

QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4
TBA-FIISB	37.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - disk_full_action
```

```
Non-compliant file(s):
```

```
    /etc/audit/auditd.conf - regex '(?i)^\s*disk_full_action\s*=' found - expect '(?i)^\s*disk_full_action\s*=[\s]*(halt|single)\s*$' not found in the following lines:
        24: disk_full_action = SUSPEND
```

```
-----
FAILED - disk_error_action = root
```

```
Non-compliant file(s):
```

```
    /etc/audit/auditd.conf - regex '(?i)^\s*disk_error_action\s*=' found - expect '(?i)^\s*disk_error_action\s*=[\s]*(syslog|single|halt)\s*$' not found in the following lines:
        25: disk_error_action = SUSPEND
```

3.2.2 Ensure tipc kernel module is not available

Info

The Transparent Inter-Process Communication (TIPC) protocol is designed to provide communication between cluster nodes. - IF - the protocol is not being used, it is recommended that kernel module not be loaded, disabling the service to reduce the potential attack surface.

Solution

Run the following script to unload and disable the tipc module: - IF - the tipc kernel module is available in ANY installed kernel: - Create a file ending in .conf with install tipc /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist tipc in the /etc/modprobe.d/ directory - Run modprobe -r tipc 2>/dev/null; rmmod tipc 2>/dev/null to remove tipc from the kernel - IF - the tipc kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary

```
#!/usr/bin/env bash
a_output2=()
a_output3=()
l_dl=""
l_mod_name="tipc"
l_mod_type="net"
l_mod_path=$(readlink -f /lib/modules/**/kernel/$l_mod_type | sort -u)
f_module_fix() { l_dl="y"
a_showconfig=()
while IFS= read -r l_showconfig; do
a_showconfig+="$l_showconfig"
done < <(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+${l_mod_chk_name}/-/_\b')
if [ $(lsmod | grep "$l_mod_chk_name" &> /dev/null) ]; then
a_output2+=(" - unloading kernel module: \"$l_mod_name\"")
modprobe -r "$l_mod_chk_name" 2>/dev/null;
rmmod "$l_mod_name" 2>/dev/null
fi
if ! grep -Pq -- '\binstall\h+${l_mod_chk_name}/-/_\b' <<< "$a_showconfig[*]"; then
a_output2+=(" - setting kernel module: \"$l_mod_name\" to \"$l_mod_path\"")
printf '%s\n' "install $l_mod_chk_name $l_mod_path" >> /etc/modprobe.d/"$l_mod_name".conf
fi
if ! grep -Pq -- '\bblacklist\h+${l_mod_chk_name}/-/_\b' <<< "$a_showconfig[*]"; then
a_output2+=(" - denylisting kernel module: \"$l_mod_name\"")
printf '%s\n' "blacklist $l_mod_chk_name" >> /etc/modprobe.d/"$l_mod_name".conf
fi
}
for l_mod_base_directory in $(ls -d "$l_mod_path"/*); do
# Check if the module exists on the system
if [ -d "$l_mod_base_directory/$l_mod_name" ]; then
a_output3+=(" - \"$l_mod_name\" exists in: \"$l_mod_base_directory/$l_mod_name\"")
else
a_output3+=(" - \"$l_mod_name\" doesn't exist in \"$l_mod_base_directory\"")
fi
done
if [ "${#a_output3[@]}" -gt 0 ]; then
printf '%s\n' "" -- INFO -- " - module: \"$l_mod_name\" exists in: " "${a_output3[@]}" [ "${#a_output2[@]}" -gt 0 ] &&
printf '%s\n' "" "${a_output2[@]}" | printf '%s\n' "" " - No changes needed"
printf '%s\n' "" " - remediation of kernel module: \"$l_mod_name\" complete" ""
else
printf '%s\n' "" " - No changes needed"
printf '%s\n' "" " - remediation of kernel module: \"$l_mod_name\" complete" ""
fi
```

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.14.6
800-171	3.14.7
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.14.06
800-53	CM-6
800-53	CM-7
800-53	SI-4
800-53R5	CM-7
800-53R5	SI-4

CN-L3	7.1.3.5(a)
CN-L3	8.1.10.5(b)
CN-L3	8.1.10.6(f)
CSCV7	9.2
CSCV8	4.8
CSF	DE.AE-1
CSF	DE.AE-2
CSF	DE.AE-3
CSF	DE.AE-4
CSF	DE.CM-1
CSF	DE.CM-5
CSF	DE.CM-6
CSF	DE.CM-7
CSF	DE.DP-2
CSF	DE.DP-3
CSF	DE.DP-4
CSF	DE.DP-5
CSF	ID.RA-1
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.IP-8
CSF	PR.PT-3
CSF	RS.AN-1
CSF	RS.CO-3
CSF2.0	DE.AE-02
CSF2.0	DE.AE-03
CSF2.0	DE.CM-01
CSF2.0	DE.CM-06
CSF2.0	DE.CM-09
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02

CSF2.0	ID.IM-03
CSF2.0	ID.RA-01
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.16
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	SI-4
LEVEL	2A
NESA	M1.2.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	5.2.3
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
-- INFO --
- module: "tipc" exists in:
  - "/usr/lib/modules/6.17.0-1018-azure/kernel/net"

- Audit Result:
  ** FAIL **
```

- Reason(s) for audit failure:
 - kernel module: "tipc" is loadable
 - kernel module: "tipc" is not deny listed
- Correctly set:
 - kernel module: "tipc" is not loaded

6.2.3.20 Ensure the audit configuration is immutable

Info

Set system audit so that audit rules cannot be modified with auditctl.
Setting the flag "-e 2" forces audit to be put in immutable mode.
Audit changes can only be made on system reboot. Note: This setting will require the system to be rebooted to update the active auditd configuration settings. In immutable mode, unauthorized users cannot execute changes to the audit system to potentially hide malicious activity and then put the audit rules back.
Users would most likely notice a system reboot and that could alert administrators of an attempt to make unauthorized audit changes.

Solution

Edit or create the file /etc/audit/rules.d/99-finalize.rules and add the line -e 2 at the end of the file: Example: # printf '\n%s' "-e 2" >> /etc/audit/rules.d/99-finalize.rules Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3

800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	MP-2
800-53R5	AC-3
800-53R5	AU-3
800-53R5	AU-12
800-53R5	MP-2
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	6.2
CSCV7	6.3
CSCV8	3.3
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.AC-4

CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20

ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a

NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command `'/bin/grep -Ph -- '^h*-e\h+2\b' /etc/audit/rules.d/*.rules | /bin/tail -1'` did not return any result

6.2.3.10 Ensure successful file system mounts are collected

Info

Monitor the use of the mount system call.

The mount (and umount) system call controls the mounting and unmounting of file systems.

The parameters below configure the system to create an audit record when the mount system call is used by a non-privileged user. It is highly unusual for a non-privileged user to mount file systems to the system.

While tracking mount commands gives the system administrator evidence that external media may have been mounted (based on a review of the source of the mount and confirming it's an external media type), it does not conclusively indicate that data was exported to the media.

System administrators who wish to determine if data were exported, would also have to track successful open, creat and truncate system calls requiring write access to a file under the mount point of the external media file system.

This could give a fair indication that a write occurred.

The only way to truly prove it, would be to track successful writes to the external media.

Tracking write system calls could quickly fill up the audit log and is not recommended.

Recommendations on configuration options to track data export to media is beyond the scope of this document.

Solution

Create audit rules. Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor successful file system mounts. Example: # { UID_MIN=\$(awk '/^s*UID_MIN/{print \$2}' /etc/login.defs) [-n "\${UID_MIN}"] && printf " -a always,exit -F arch=b32 -S mount -F auid>=\$UID_MIN -F auid!=unset -k mounts -a always,exit -F arch=b64 -S mount -F auid>=\$UID_MIN -F auid!=unset -k mounts " >> /etc/audit/rules.d/50-mounts.rules | | printf "ERROR: Variable 'UID_MIN' is unset.\n" } Load audit rules. Merge and load the rules into active configuration: # augenrules --load. Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6
800-53R5	CM-6
CN-L3	7.1.2.3(a)

CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	6.3
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12

ITSG-33	CM-6
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl b64
The command 'UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&
auditctl -l | awk '/^ *-a *always,exit/ &&/ -F *arch=b64/ &&/ -F *auid!=unset/||/ -F *auid!
=-1/||/ -F *auid!=4294967295/) &&/ -F *auid>=${UID_MIN}/ &&/ -S/ &&/mount/ &&/ key= *[*~]* *'
```

```
$/||/ -k *[-~]* *$/" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' ||  
printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - b32

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "/^ *-a *always,exit/ &&/ -F *arch=b32/ &&/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!  
=4294967295/) &&/ -F *auid>=${UID_MIN}/ &&/ -S/ &&/mount/ &&/ key= *[-~]* *$/" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - b64

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
awk "/^ *-a *always,exit/ &&/ -F *arch=b64/ &&/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!  
=4294967295/) &&/ -F *auid>=${UID_MIN}/ &&/ -S/ &&/mount/ &&/ key= *[-~]* *$/" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' || printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

FAILED - auditctl b32

```
The command 'UID_MIN=$(awk '/^s*UID_MIN/{print $2}' /etc/login.defs); [ -n "${UID_MIN}" ] &&  
auditctl -l | awk "/^ *-a *always,exit/ &&/ -F *arch=b32/ &&/ -F *auid!=unset/||/ -F *auid!  
=-1/||/ -F *auid!=4294967295/) &&/ -F *auid>=${UID_MIN}/ &&/ -S/ &&/mount/ &&/ key= *[-~]* *  
$/" | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' ||  
printf "ERROR: Variable 'UID_MIN' is unset.\n" returned :
```

fail

6.2.3.4 Ensure events that modify date and time information are collected

Info

Capture events where the system date and/or time has been modified.

The parameters in this section are set to determine if the; - adjtimex - tune kernel clock - settimeofday - set time using timeval and timezone structures - stime - using seconds since 1/1/1970 - clock_settime - allows for the setting of several internal clocks and timers system calls have been executed.

Further, ensure to write an audit record to the configured audit log file upon exit, tagging the records with a unique identifier such as "time-change". Unexpected changes in system date and/or time could be a sign of malicious activity on the system.

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor events that modify date and time information. Example: # printf " -a always,exit -F arch=b64 -S adjtimex,settimeofday -k time-change -a always,exit -F arch=b32 -S adjtimex,settimeofday -k time-change -a always,exit -F arch=b64 -S clock_settime -F a0=0x0 -k time-change -a always,exit -F arch=b32 -S clock_settime -F a0=0x0 -k time-change -w /etc/localtime -p wa -k time-change " >> /etc/audit/rules.d/50-time-change.rules Load audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6
800-53R5	AU-3
800-53R5	CM-6
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)

CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	5.5
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	CM-6
LEVEL	2A
NESA	T3.6.2

NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - settimeofday b32
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/
&&/settimeofday/ &&/ key= *[:-~]* *$/||/ -k *[:-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----
FAILED - auditctl settimeofday x64
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F
*arch=b64/ &&/ -S/ &&/settimeofday/ &&/ key= *[:-~]* *$/||/ -k *[:-~]* *$/)' | /bin/awk '{print}
END {if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----  
FAILED - adjtimex x64  
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/ &&/  
adjtimex/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print}  
END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - settimeofday x64  
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/  
&&/settimeofday/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk  
'{print} END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - auditctl clock_settime b32  
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/  
-F *arch=b32/ &&/ -S/ &&/clock_settime/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk  
'{print} END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - auditctl clock_settime x64  
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/  
-F *arch=b64/ &&/ -S/ &&/clock_settime/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk  
'{print} END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - adjtimex b32  
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/ &&/  
adjtimex/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print}  
END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - /etc/localtime  
The command '/bin/awk '(/^ *-w/ &&/\etc\localtime/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]  
~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else  
print "fail"}'' returned :
```

fail

```
-----  
FAILED - clock_settime x64  
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/ &&/  
clock_settime/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk  
'{print} END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - clock_settime b32  
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/ &&/  
clock_settime/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk  
'{print} END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - auditctl settimeofday b32  
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F  
*arch=b32/ &&/ -S/ &&/settimeofday/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print}  
END {if (NR != 0) print "pass" ; else print "fail"}'' returned :
```

fail

```
-----  
FAILED - auditctl /etc/localtime  
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/localtime/ &&/ +-p *wa/ &&/ key=  
*[!~]* *$/||/ -k *[!~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print  
"fail"}' returned :
```

fail

```
-----  
FAILED - auditctl adjtimex b32  
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F  
*arch=b32/ &&/ -S/ &&/adjtimex/ &&/ key= *[!~]* *$/||/ -k *[!~]* *$/)' | /bin/awk '{print} END  
{if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

```
-----  
FAILED - auditctl adjtimex x64  
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F  
*arch=b64/ &&/ -S/ &&/adjtimex/ &&/ key= *[!~]* *$/||/ -k *[!~]* *$/)' | /bin/awk '{print} END  
{if (NR != 0) print "pass" ; else print "fail"}' returned :
```

fail

6.2.3.6 Ensure use of privileged commands are collected

Info

Monitor privileged programs, those that have the setuid and/or setgid bit set on execution, to determine if unprivileged users are running these commands. Execution of privileged commands by non-privileged users could be an indication of someone trying to gain unauthorized access to the system.

Solution

Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor the use of privileged commands. Example script: `#!/usr/bin/env bash { UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs) AUDIT_RULE_FILE="/etc/audit/rules.d/50-privileged.rules" NEW_DATA=() for PARTITION in $(findmnt -n -l -k -it $(awk '/nodev/{ print $2 }' /proc/filesystems | paste -sd,) | grep -Pv "noexec|nosuid" | awk '{print $1}'); do readarray -t DATA < <(find "${PARTITION}" -xdev -perm /6000 -type f | awk -v UID_MIN=${UID_MIN} '{print "-a always,exit -F path=" $1 " -F perm=x -F auid>="UID_MIN" -F auid! =unset -k privileged" }') for ENTRY in "${DATA[@]}"; do NEW_DATA+=("${ENTRY}") done done readarray &> /dev/null -t OLD_DATA < "${AUDIT_RULE_FILE}" COMBINED_DATA=("${OLD_DATA[@]}" "${NEW_DATA[@]}") printf '%s\n' "${COMBINED_DATA[@]}" | sort -u > "${AUDIT_RULE_FILE}" } Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi Special mount points If there are any special mount points that are not visible by default from just scanning /, change the PARTITION variable to the appropriate partition and re-run the remediation. Impact: Both the audit and remediation section of this recommendation will traverse all mounted file systems that is not mounted with either noexec or nosuid mount options.`

If there are large file systems without these mount options, such traversal will be significantly detrimental to the performance of the system. Before running either the audit or remediation section, inspect the output of the following command to determine exactly which file systems will be traversed: `# findmnt -n -l -k -it $(awk '/nodev/{ print $2 }' /proc/filesystems | paste -sd,) | grep -Pv "noexec|nosuid"` To exclude a particular file system due to adverse performance impacts, update the audit and remediation sections by adding a sufficiently unique string to the grep statement.

The above command can be used to test the modified exclusions.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
800-53R5	AU-3(1)
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)

CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	6.2
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b

NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl
The command 'RUNNING=$(/sbin/auditctl -l); [ -n "${RUNNING}" ] && for PARTITION in $(/bin/findmnt
-n -l -k -it $(/bin/awk '/nodev/ { print $2 }' /proc/filesystems | paste -sd,) | /bin/grep -Pv
"noexec|nosuid" | /bin/awk '{print $1}'); do for PRIVILEGED in $(/bin/find "${PARTITION}" -xdev
-perm /6000 -type f); do printf -- "${RUNNING}" | /bin/grep -q "${PRIVILEGED}" && printf "OK:
'${PRIVILEGED}' found in auditing rules.\n" || printf "Warning: '${PRIVILEGED}' not found in
running configuration.\n"; done; done | /bin/awk '{print} END { if ($1 ~ "Warning") print "Fail -
Warnings found"; else print "Pass - No warning entries found" }' returned :
```

Warning: '/usr/sbin/pam_extrausers_chkpwd' not found in running configuration.
Warning: '/usr/sbin/mount.cifs' not found in running configuration.
Warning: '/usr/sbin/unix_chkpwd' not found in running configuration.
Warning: '/usr/lib/x86_64-linux-gnu/utempter/utempter' not found in running configuration.
Warning: '/usr/lib/openssh/ssh-keysign' not found in running configuration.
Warning: '/usr/lib/dbus-1.0/dbus-daemon-launch-helper' not found in running configuration.
Warning: '/usr/lib/polkit-1/polkit-agent-helper-1' not found in running configuration.
Warning: '/usr/bin/su' not found in running configuration.
Warning: '/usr/bin/chsh' not found in running configuration.
Warning: '/usr/bin/newgrp' not found in running configuration.

Warning: '/usr/bin/umount' not found in running configuration.
Warning: '/usr/bin/passwd' not found in running configuration.
Warning: '/usr/bin/fusermount3' not found in running configuration.
Warning: '/usr/bin/expiry' not found in running configuration.
Warning: '/usr/bin/gpasswd' not found in running configuration.
Warning: '/usr/bin/mount' not found in running configuration.
Warning: '/usr/bin/chage' not found in running configuration.
Warning: '/usr/bin/crontab' not found in running configuration.
Warning: '/usr/bin/sudo' not found in running configuration.
Warning: '/usr/bin/ssh-agent' not found in running configuration.
Warning: '/usr/bin/chfn' not found in running configuration.
Fail - Warnings found

FAILED - /etc/audit/rules.d

The command 'for PARTITION in \$(/bin/findmnt -n -l -k -it \$(/bin/awk '/nodev/ { print \$2 }' /proc/filesystems | paste -sd,) | /bin/grep -Pv "noexec|nosuid" | /bin/awk '{print \$1}'); do for PRIVILEGED in \$(/bin/find "\${PARTITION}" -xdev -perm /6000 -type f); do /bin/grep -qr "\${PRIVILEGED}" /etc/audit/rules.d && printf "OK: '\${PRIVILEGED}' found in auditing rules.\n" || printf "Warning: '\${PRIVILEGED}' not found in on disk configuration.\n"; done; done | /bin/awk '{print} END { if (\$1 ~ "Warning") print "Fail - Warnings found"; else print "Pass - No warning entries found" }' returned :

Warning: '/usr/sbin/pam_extrausers_chkpwd' not found in on disk configuration.
Warning: '/usr/sbin/mount.cifs' not found in on disk configuration.
Warning: '/usr/sbin/unix_chkpwd' not found in on disk configuration.
Warning: '/usr/lib/x86_64-linux-gnu/utempter/utempter' not found in on disk configuration.
Warning: '/usr/lib/openssh/ssh-keysign' not found in on disk configuration.
Warning: '/usr/lib/dbus-1.0/dbus-daemon-launch-helper' not found in on disk configuration.
Warning: '/usr/lib/polkit-1/polkit-agent-helper-1' not found in on disk configuration.
Warning: '/usr/bin/su' not found in on disk configuration.
Warning: '/usr/bin/chsh' not found in on disk configuration.
Warning: '/usr/bin/newgrp' not found in on disk configuration.
Warning: '/usr/bin/umount' not found in on disk configuration.
Warning: '/usr/bin/passwd' not found in on disk configuration.
Warning: '/usr/bin/fusermount3' not found in on disk configuration.
Warning: '/usr/bin/expiry' not found in on disk configuration.
Warning: '/usr/bin/gpasswd' not found in on disk configuration.
Warning: '/usr/bin/mount' not found in on disk configuration.
Warning: '/usr/bin/chage' not found in on disk configuration.
Warning: '/usr/bin/crontab' not found in on disk configuration.
Warning: '/usr/bin/sudo' not found in on disk configuration.
Warning: '/usr/bin/ssh-agent' not found in on disk configuration.
Warning: '/usr/bin/chfn' not found in on disk configuration.
Fail - Warnings found

6.2.3.14 Ensure events that modify the system's Mandatory Access Controls are collected

Info

Monitor AppArmor, an implementation of mandatory access controls.

The parameters below monitor any write access (potential additional, deletion or modification of files in the directory) or attribute changes to the `/etc/apparmor/` and `/etc/apparmor.d/` directories. Note: If a different Mandatory Access Control method is used, changes to the corresponding directories should be audited. Changes to files in the `/etc/apparmor/` and `/etc/apparmor.d/` directories could indicate that an unauthorized user is attempting to modify access controls and change security contexts, leading to a compromise of the system.

Solution

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify the system's Mandatory Access Controls. Example: `# printf " -w /etc/apparmor/ -p wa -k MAC-policy -w /etc/apparmor.d/ -p wa -k MAC-policy" >> /etc/audit/rules.d/50-MAC-policy.rules` Merge and load the rules into active configuration: `# augenrules --load` Check if reboot is required. `# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot required to load rules\n"; fi`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6
800-53R5	AU-3
800-53R5	CM-6
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)

CN-L3	8.1.4.3(b)
CSCV7	5.5
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	CM-6
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a

NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl - /etc/apparmor.d/
The command '/sbin/auditctl -l 2>/dev/null | /bin/awk '/^ *-w/ && /\etc\apparmor.d/ && / +-p *wa/ && (/ key= *[-~]* *$/||/ -k *[-~]* *$)/' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - rules - /etc/apparmor/
The command '/bin/awk '/^ *-w/ && /\etc\apparmor/ && / +-p *wa/ && (/ key= *[-~]* *$/||/ -k *[-~]* *$)/' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail
```

```
-----  
FAILED - rules - /etc/apparmor.d/  
The command '/bin/awk '/^ *-w/ && /\etc\apparmor.d/ && / +-p *wa/ && (/ key= *[-~]* *$/||/ -  
k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ;  
else print "fail"}'' returned :
```

fail

```
-----  
FAILED - auditctl - /etc/apparmor/  
The command '/sbin/auditctl -l 2>/dev/null | /bin/awk '/^ *-w/ && /\etc\apparmor/ && / +-p *wa/  
&& (/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ;  
else print "fail"}'' returned :
```

fail

1.1.2.4.1 Ensure separate partition exists for /var

Info

The /var directory is used by daemons and other system services to temporarily store dynamic data. Some directories created by these processes may be world-writable. The reasoning for mounting /var on a separate partition is as follows. The default installation only creates a single / partition. Since the /var directory may contain world writable files and directories, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system. In addition, other operations on the system could fill up the disk unrelated to /var and cause unintended behavior across the system as the disk is full. See man auditd.conf for details. Configuring /var as its own file system allows an administrator to set additional mount options such as noexec/nosuid/nODEV. These options limit an attacker's ability to create exploits on the system. Other options allow for specific behavior. See man mount for exact details regarding filesystem-independent and filesystem-specific options. An example of exploiting /var may be an attacker establishing a hard-link to a system setuid program and waiting for it to be updated. Once the program is updated, the hard-link can be broken and the attacker would have their own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

Solution

For new installations, during installation create a custom partition setup and specify a separate partition for /var. For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate. Impact: Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.4.6
800-171	3.4.7
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.04.06
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5

800-53	AC-6
800-53	CM-7
800-53	MP-2
800-53R5	CM-7
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33

ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	CM-7
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3

NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15a
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	2.2.2
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	5.1
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

The following file(s) do not contain "[\s]+/var[\s]+":
 /proc/self/mountinfo

6.2.1.4 Ensure audit_backlog_limit is sufficient

Info

In the kernel-level audit subsystem, a socket buffer queue is used to hold audit events.

Whenever a new audit event is received, it is logged and prepared to be added to this queue. The kernel boot parameter `audit_backlog_limit=N`, with N representing the amount of messages, will ensure that a queue cannot grow beyond a certain size.

If an audit event is logged which would grow the queue beyond this limit, then a failure occurs and is handled according to the system configuration. If an audit event is logged which would grow the queue beyond the `audit_backlog_limit`, then a failure occurs, `auditd` records will be lost, and potential malicious activity could go undetected.

Solution

Edit `/etc/default/grub` and add `audit_backlog_limit=N` to `GRUB_CMDLINE_LINUX`.

The recommended size for N is 8192 or larger. Example: `GRUB_CMDLINE_LINUX="audit_backlog_limit=8192"`

Run the following command to update the grub2 configuration: `# update-grub`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.01
800-171R3	03.03.02a.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-2
800-53	AU-3
800-53	AU-7
800-53	AU-12
800-53R5	AU-2
800-53R5	AU-3
800-53R5	AU-12
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.3(a)
CN-L3	8.1.4.3(b)
CSCV7	6.2

CSCV7	6.3
CSCV8	8.2
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-3
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T3.6.2
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c

NIAV2	AM11d
NIAV2	AM11e
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

The command `'/bin/find /boot -type f -name 'grub.cfg' -exec /bin/grep -Ph -- '^h*linux' {} + | /bin/grep -Pv 'audit_backlog_limit=\d+\b' | /bin/awk '{print} END { if (NR==0) print "pass" }'` returned :

```
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240 panic=-1
```

```
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro
console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240 panic=-1
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro recovery
nomodeset dis_ucode_ldr console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
linux /vmlinuz-6.17.0-1018-azure root=PARTUUID=013653c3-58f6-4f8b-8efd-589eb0f716fc ro recovery
nomodeset dis_ucode_ldr console=tty1 console=ttyS0 earlyprintk=ttyS0 nvme_core.io_timeout=240
panic=-1
```

5.1.8 Ensure sshd DisableForwarding is enabled

Info

The DisableForwarding parameter disables all forwarding features, including X11, ssh-agent(1), TCP and StreamLocal.

This option overrides all other forwarding-related options and may simplify restricted configurations. - X11Forwarding provides the ability to tunnel X11 traffic through the connection to enable remote graphic connections. - ssh-agent is a program to hold private keys used for public key authentication.

Through use of environment variables the agent can be located and automatically used for authentication when logging in to other machines using ssh. - SSH port forwarding is a mechanism in SSH for tunneling application ports from the client to the server, or servers to clients.

It can be used for adding encryption to legacy applications, going through firewalls, and some system administrators and IT professionals use it for opening backdoors into the internal network from their home machines. Disable X11 forwarding unless there is an operational requirement to use X11 applications directly. There is a small risk that the remote X11 servers of users who are logged in via SSH with X11 forwarding could be compromised by other users on the X11 server.

Note that even if X11 forwarding is disabled, users can always install their own forwarders. anyone with root privilege on the the intermediate server can make free use of ssh-agent to authenticate them to other servers Leaving port forwarding enabled can expose the organization to security risks and backdoors.

SSH connections are protected with strong encryption.

This makes their contents invisible to most deployed network monitoring and traffic filtering solutions.

This invisibility carries considerable risk potential if it is used for malicious purposes such as data exfiltration.

Cybercriminals or malware could exploit SSH to hide their unauthorized communications, or to exfiltrate stolen data from the target network.

Solution

Edit the /etc/ssh/sshd_config file to set the DisableForwarding parameter to yes above any Include entry as follows: DisableForwarding yes Note: First occurrence of a option takes precedence.

If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location. Impact: SSH tunnels are widely used in many corporate environments.

In some environments the applications themselves may have very limited native support for security.

By utilizing tunneling, compliance with SOX, HIPAA, PCI-DSS, and other standards can be achieved without having to modify the applications.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53R5	CM-7
CSCV7	9.2
CSCV8	4.8
CSF	PR.IP-1
CSF	PR.PT-3

CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
port 22: disableforwarding no
Fail
```

5.2.4 Ensure users must provide password for privilege escalation

Info

The operating system must be configured so that users must provide a password for privilege escalation. Without (re-)authentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the user (re-)authenticate.

Solution

Based on the outcome of the audit procedure, use `visudo -f <PATH TO FILE>` to edit the relevant sudoers file. Remove any line with occurrences of NOPASSWD tags in the file. Impact: This will prevent automated processes from being able to elevate privileges.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.5
800-171	3.1.6
800-171R3	03.01.05a.
800-171R3	03.01.06a.
800-171R3	03.01.06b.
800-53	AC-6
800-53	AC-6(2)
800-53	AC-6(5)
800-53R5	AC-6
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.10.6(a)
CSCV7	4.3
CSCV8	5.4
CSF	PR.AC-4
CSF	PR.DS-5
CSF2.0	PR.AA-05
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2

ISO-27001-2022	A.8.18
ISO/IEC-27001	A.9.2.3
ITSG-33	AC-6
ITSG-33	AC-6(2)
ITSG-33	AC-6(5)
LEVEL	2A
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM23f
NIAV2	AM32
NIAV2	AM33
NIAV2	SS13c
NIAV2	SS15c
NIAV2	VL3a
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	13.2
SWIFT-CSCV1	1.2
SWIFT-CSCV1	5.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

Non-compliant file(s):

```
/etc/sudoers.d/90-cloud-init-users - regex '^[^#]*NOPASSWD' found - expect '^[^#]*NOPASSWD'  
found in the following lines:  
4: lababel ALL=(ALL) NOPASSWD:ALL
```

6.3.3 Ensure cryptographic mechanisms are used to protect the integrity of audit tools

Info

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records.

Audit tools include custom queries and report generators. aide.conf is case-sensitive.

Leading and trailing white spaces are ignored.

Each config lines must end with new line. AIDE uses the backslash character \ as escape character for ' ' (space), '@' and " (backslash) (e.g. \ ' or '@').

To literally match a " in a file path with a regular expression you have to escape the backslash twice (i.e. '\\').

There are three types of lines in aide.conf :

- The configuration options which are used to set configuration parameters and define groups.
- (restricted) rules that are used to indicate which files are added to the database.
- Macro lines define or undefine variables within the config file. Note: Lines beginning with # are ignored as comments.

@@include <FILE> - Include <FILE>. - The content of the file is used as if it were inserted in this part of the config file.

The maximum depth of nested includes is 16.

@@include <DIRECTORY> <REGEX> - [RULE_PREFIX] (added in AIDE v0.17) - Include all (regular) files found in <DIRECTORY> matching regular expression <REGEX> (sub-directories are ignored).

The file are included in lexical sort order.

If RULE_PREFIX is set, all rules included by the statement are prefixed with given <RULE_PREFIX> (added in AIDE v0.18).

Prefixes from nested include statements are concatenated.

The content of the files is used as if it were inserted in this part of the config file.

@x_include : - is identical to @@include, except that if a config file is executable is is run and the output is used as config.

If the executable file exits with status greater than zero or writes to stderr aide stops with an error.

For security reasons <DIRECTORY> and each executable config file must be owned by the current user or root.

They must not be group- or world-writable.

@@x_include _<FILE>_ (added in AIDE v0.17): - `@@x_include <DIRECTORY> <REGEX> [RULE_PREFIX] (added in AIDE v0.17) @@x_include_setenv <VAR> <VALUE> (added in AIDE v0.17) - Adds the variable <VAR> with the value <VALUE> to the environment used for config file execution.

Environment variable names are limited to alphanumeric characters (A-Za-z0-9) and the underscore '_' and must not begin with a digit.

Protecting the integrity of the tools used for auditing purposes is a critical step toward ensuring the integrity of audit information.

Audit information includes all information (e.g., audit records, audit settings, and audit reports) needed to successfully audit information system activity.

Attackers may replace the audit tools or inject code into the existing tools with the purpose of providing the capability to hide or erase system activity from the audit logs.

Audit tools should be cryptographically signed in order to provide the capability to identify when the audit tools have been modified, manipulated, or replaced.

An example is a checksum hash of the file or files.

Solution

Run the following command to determine the absolute path to the non-symlinked version on the audit tools: # readlink -f /sbin The output will be either /usr/sbin - OR - /sbin.

Ensure the correct path is used. Edit /etc/aide/aide.conf and add or update the following selection lines replacing <PATH> with the correct path returned in the command above:

```
# Audit Tools <PATH>/auditctl p+i+n+u+g+s+b+acl+xattrs+sha512 <PATH>/auditd p+i+n+u+g+s+b+acl+xattrs+sha512 <PATH>/ausearch p+i+n+u+g+s+b+acl+xattrs+sha512 <PATH>/aureport p+i+n+u+g+s+b+acl+xattrs+sha512 <PATH>/autrace p+i+n+u+g+s+b+acl+xattrs+sha512 <PATH>/augenrules p+i+n+u+g+s+b+acl+xattrs+sha512
```

Example

```
# printf '%s\n' "" "# Audit Tools" "$(readlink -f /sbin/auditctl) p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/auditd) p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/ausearch) p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/aureport) p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/autrace) p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/augenrules) p+i+n+u+g+s+b+acl+xattrs+sha512" >> /etc/aide/aide.conf
```

Note: - IF - /etc/aide/aide.conf includes a @@x_include statement: - <DIRECTORY> and each executable config file must be owned by the current user or root - They must not be group or world-writable

Example: @@x_include /etc/aide.conf.d ^[a-zA-Z0-9_-]+\$

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-53	SI-7
800-53R5	SI-7
CSF	PR.DS-6

CSF2.0	DE.CM-09
CSF2.0	ID.RA-09
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.PS-02
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(c)(1)
HIPAA	164.312(c)(2)
HIPAA	164.312(e)(2)(i)
ITSG-33	SI-7
ITSG-33	SI-7a.
LEVEL	2A
NESA	T3.4.1
NESA	T7.3.2
NESA	T7.3.3
PCI-DSSV3.2.1	10.5.5
QCSC-V1	3.2

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** FAIL **
- Reason(s) for audit failure:
 - The command "aide" was not found
 - Please install AIDE

5.3.3.1.3 Ensure password failed attempts lockout includes root account

Info

even_deny_root - Root account can become locked as well as regular accounts root_unlock_time=n - This option implies even_deny_root option.

Allow access after n seconds to root account after the account is locked.

In case the option is not specified the value is the same as of the unlock_time option. Locking out user IDs after n unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

Solution

Edit /etc/security/faillock.conf : - Remove or update any line containing root_unlock_time, - OR - set it to a value of 60 or more - Update or add the following line: even_deny_root Run the following command: # grep -PI -- '\bpam_faillock\.so\h+([^\n\r]+\h+)?(even_deny_root|root_unlock_time)' /usr/share/pam-configs/* Edit any returned files and remove the even_deny_root and root_unlock_time arguments from the pam_faillock.so line(s): Impact: Use of unlock_time=0 or root_unlock_time=0 may allow an attacker to cause denial of service to legitimate users.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171R3	03.01.01
800-171R3	03.15.01
800-53	AC-1
800-53	AC-2
800-53	AC-2(1)
800-53R5	AC-1
800-53R5	AC-2
800-53R5	AC-2(1)
CN-L3	7.1.3.2(d)
CN-L3	8.1.4.2(e)
CN-L3	8.1.10.6(c)
CSCV7	16.7
CSCV8	6.2
CSF	DE.CM-1
CSF	DE.CM-3
CSF	ID.GV-1
CSF	ID.GV-3
CSF	PR.AC-1
CSF	PR.AC-4
CSF2.0	DE.CM-01

CSF2.0	DE.CM-03
CSF2.0	GV.OC-03
CSF2.0	GV.OV-01
CSF2.0	GV.PO-01
CSF2.0	GV.PO-02
CSF2.0	GV.SC-03
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	PR.AA-01
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.1
ISO-27001-2022	A.5.2
ISO-27001-2022	A.5.4
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.18
ISO-27001-2022	A.5.31
ISO-27001-2022	A.5.36
ISO-27001-2022	A.5.37
ISO-27001-2022	A.8.2
ISO-27001-2022	5.2
ISO-27001-2022	5.3
ISO-27001-2022	7.5.1
ISO-27001-2022	7.5.2
ISO-27001-2022	7.5.3
ISO/IEC-27001	A.9.1.1

ISO/IEC-27001	A.9.2.1
ITSG-33	AC-1
ITSG-33	AC-2
ITSG-33	AC-2(1)
LEVEL	2A
NESA	M1.2.2
NIAV2	AM28
NIAV2	AM29
NIAV2	AM30
NIAV2	NS5j
NIAV2	SS14e
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	8.2.1
QCSC-V1	13.2
QCSC-V1	15.2

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```

-----
FAILED - /etc/security/faillock.conf even_deny_root or root_unlock_time
The following file(s) do not contain "(?i)^\h*(even_deny_root|root_unlock_time\h*=\h*\d+)\b":
/etc/security/faillock.conf

-----
PASSED - /etc/security/faillock.conf root_unlock_time value
No matching files were found

-----
PASSED - common-auth root_unlock_time
No matching files were found

```

1.1.2.7.1 Ensure separate partition exists for /var/log/audit

Info

The auditing daemon, auditd, stores log data in the /var/log/audit directory. The default installation only creates a single / partition.

Since the /var/log/audit directory contains the audit.log file which can grow quite large, there is a risk of resource exhaustion.

It will essentially have the whole disk available to fill up and impact the system as a whole.

In addition, other operations on the system could fill up the disk unrelated to /var/log/audit and cause auditd to trigger its space_left_action as the disk is full.

See man auditd.conf for details. Configuring /var/log/audit as its own file system allows an administrator to set additional mount options such as noexec/nosuid/noddev.

These options limit an attacker's ability to create exploits on the system.

Other options allow for specific behavior.

See man mount for exact details regarding filesystem-independent and filesystem-specific options. As /var/log/audit contains audit logs, care should be taken to ensure the security and integrity of the data and mount point.

Solution

For new installations, during installation create a custom partition setup and specify a separate partition for /var/log/audit. For systems that were previously installed, create a new partition and configure /etc/fstab as appropriate. Impact: Resizing filesystems is a common activity in cloud-hosted servers.

Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations.

The use of these additional tools may introduce their own security considerations.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06
800-53	AU-4
800-53	CM-7
800-53R5	CM-7
CSCV7	6.4
CSCV8	8.3
CSF	PR.DS-4
CSF	PR.IP-1
CSF	PR.PT-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6

ITSG-33	AU-4
ITSG-33	CM-7
LEVEL	2A
NESA	T3.3.1
NESA	T3.6.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The following file(s) do not contain "[\s]+/var/log/audit[\s]+":
 /proc/self/mountinfo

6.2.3.5 Ensure events that modify the system's network environment are collected

Info

Record changes to network environment files or system calls.

The below parameters monitors the following system calls, and write an audit event on system call exit: -

sethostname - set the systems host name - setdomainname - set the systems domain name The files being

monitored are: - /etc/issue and /etc/issue.net - messages displayed pre-login - /etc/hosts - file containing

host names and associated IP addresses - /etc/networks - symbolic names for networks - /etc/network/ -

directory containing network interface scripts and configurations files - /etc/netplan/ - central location for

YAML networking configurations files Monitoring system events that change network environments, such as

sethostname and setdomainname, helps identify unauthorized alterations to host and domain names, which could compromise security settings reliant on these names.

Changes to /etc/hosts can signal unauthorized attempts to alter machine associations with IP addresses, potentially redirecting users and processes to unintended destinations.

Surveillance of /etc/issue and /etc/issue.net is crucial to detect intruders inserting false information to deceive users.

Monitoring /etc/network/ reveals modifications to network interfaces or scripts that may jeopardize system availability or security.

Additionally, tracking changes in the /etc/netplan/ directory ensures swift detection of unauthorized adjustments to network configurations.

All audit records should be appropriately tagged for relevance

Solution

Create audit rules Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor events that modify the system's network environment. Example: # printf " -

a always,exit -F arch=b64 -S sethostname,setdomainname -k system-locale -a always,exit -F arch=b32 -S

sethostname,setdomainname -k system-locale -w /etc/issue -p wa -k system-locale -w /etc/issue.net -p wa -k

system-locale -w /etc/hosts -p wa -k system-locale -w /etc/networks -p wa -k system-locale -w /etc/network/ -p

wa -k system-locale -w /etc/netplan/ -p wa -k system-locale " >> /etc/audit/rules.d/50-system_locale.rules Load

audit rules Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. #

if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.4.2
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.04.02
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	CM-6

800-53R5	AU-3
800-53R5	CM-6
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	5.5
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.15
ITSG-33	AU-3

ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	CM-6
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```

-----
FAILED - rules - /etc/network/
The command '/bin/awk '/^ *-w/ &&/etc/network// &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - /etc/issue.net
The command '/bin/awk '/^ *-w/ &&/etc/issue.net/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - rules - b32 setdomainname
The command '/bin/awk '/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/ &&/ setdomainname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - rules - /etc/networks
The command '/bin/awk '/^ *-w/ &&/etc/networks/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl b64 setdomainname
The command '/sbin/auditctl -l | /bin/awk '/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/ &&/ setdomainname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl b64 sethostname
The command '/sbin/auditctl -l | /bin/awk '/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/ &&/ sethostname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - b64 setdomainname
The command '/bin/awk '/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/ &&/ setdomainname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl b32 sethostname
The command '/sbin/auditctl -l | /bin/awk '/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/ &&/ sethostname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl /etc/network
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc/network / &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl /etc/issue.net

```

```

The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc\issue.net/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - auditctl /etc/issue
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc\issue / &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - b32 sethostname
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b32/ &&/ -S/
&&/sethostname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - auditctl - /etc/networks
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc\networks/ &&/ +-p *wa/ &&/ key=
*[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - auditctl /etc/hosts
The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&/etc\hosts/ &&/ +-p *wa/ &&/ key= *[-~]*
*$/||/ -k *[-~]* *$/)' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}'
returned :

fail

-----
FAILED - b64 sethostname
The command '/bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/ -F *arch=b64/ &&/ -S/
&&/sethostname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' /etc/audit/rules.d/*.rules | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - rules - /etc/issue
The command '/bin/awk '/^ *-w/ &&/etc\issue / &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

fail

-----
FAILED - rules - /etc/netplan/
The command '/bin/awk '/^ *-w/ &&/etc\netplan// &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else
print "fail"}' returned :

fail

-----
FAILED - auditctl b32 setdomainname
The command '/sbin/auditctl -l | /bin/awk '(/^ *-a *always,exit/||/^ *-a *exit,always/) &&/
-F *arch=b32/ &&/ -S/ &&/setdomainname/ &&/ key= *[-~]* *$/||/ -k *[-~]* *$/)' | /bin/awk
'{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

-----
FAILED - /etc/hosts
The command '/bin/awk '/^ *-w/ &&/etc\hosts/ &&/ +-p *wa/ &&/ key= *[-~]* *$/||/ -k *[-~]*
*$/)' /etc/audit/rules.d/*.rules | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print
"fail"}' returned :

```

fail

FAILED - auditctl /etc/netplan

The command '/sbin/auditctl -l | /bin/awk '/^ *-w/ &&\/etc\/netplan/ && +-p *wa/ &&(/ key= *[-~]* *\$|/ -k *[-~]* *\$/) ' | /bin/awk '{print} END {if (NR != 0) print "pass" ; else print "fail"}' returned :

fail

1.1.1.6 Ensure overlays kernel module is not available

Info

overlays is a Linux filesystem that layers multiple filesystems to create a single unified view which allows a user to "merge" several mount points into a unified filesystem. The overlays has known CVE's: CVE-2023-32629, CVE-2023-2640, CVE-2023-0386.

Disabling the overlays reduces the local attack surface by removing support for unnecessary filesystem types and mitigates potential risks associated with unauthorized execution of setuid files, enhancing the overall system security.

Solution

Run the following script to unload and disable the overlays module: - IF - the overlays kernel module is available in ANY installed kernel: - Create a file ending in .conf with install overlays /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist overlays in the /etc/modprobe.d/ directory - Run modprobe -r overlays 2>/dev/null; rmmod overlays 2>/dev/null to remove overlays from the kernel - IF - the overlays kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary #!/usr/bin/env bash { a_output2=() a_output3=() l_dl="" l_mod_name="overlays" l_mod_type="fs" l_mod_path="\$(readlink -f /lib/modules/**/kernel/\$l_mod_type | sort -u)" f_module_fix() { l_dl="y" a_showconfig=() while IFS= read -r l_showconfig; do a_showconfig+="\$l_showconfig" done < <(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+' "\${l_mod_chk_name}/-/" "\b") if lsmod | grep "\$l_mod_chk_name" &> /dev/null; then a_output2+=(" - unloading kernel module: \"\$l_mod_name\"") modprobe -r "\$l_mod_chk_name" 2>/dev/null; rmmod "\$l_mod_name" 2>/dev/null fi if ! grep -Pq -- '\binstall\h+' "\${l_mod_chk_name}/-/" "\b" && (Vusr)?VbinV(true|false)\b' <<< "\${a_showconfig[*]"; then a_output2+=(" - setting kernel module: \"\$l_mod_name\" to \"\$(readlink -f /bin/false)\"") printf '%s\n' "install \$l_mod_chk_name \$(readlink -f /bin/false)" >> /etc/modprobe.d/"\$l_mod_name".conf fi if ! grep -Pq -- '\bblacklist\h+' "\${l_mod_chk_name}/-/" "\b" <<< "\${a_showconfig[*]"; then a_output2+=(" - denylisting kernel module: \"\$l_mod_name\"") printf '%s\n' "blacklist \$l_mod_chk_name" >> /etc/modprobe.d/"\$l_mod_name".conf fi } for l_mod_base_directory in \$l_mod_path; do # Check if the module exists on the system if [-d "\$l_mod_base_directory/\$l_mod_name/-/"] && [-n "\$(ls -A "\$l_mod_base_directory/\$l_mod_name/-/")"]; then a_output3+=(" - \"\$l_mod_base_directory\"") l_mod_chk_name="\$l_mod_name" ["\$l_mod_name" =~ overlay] && l_mod_chk_name="\${l_mod_name::-2}" ["\$l_dl" != "y"] && f_module_fix else printf '%s\n' " - kernel module: \"\$l_mod_name\" doesn't exist in \"\$l_mod_base_directory\"" fi done ["\${#a_output3[@]}" -gt 0] && printf '%s\n' "" -- INFO -- " - module: \"\$l_mod_name\" exists in:" "\${a_output3[@]}" ["\${#a_output2[@]}" -gt 0] && printf '%s\n' "" "\${a_output2[@]}" | | printf '%s\n' "" " - No changes needed" printf '%s\n' "" " - remediation of kernel module: \"\$l_mod_name\" complete" "" } Impact: WARNING: If Container applications such as Docker, Kubernetes, Podman, Linux Containers (LXC), etc. are in use proceed with caution and consider the impact on containerized workloads, as disabling the overlays may severely disrupt containerization.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53R5	CM-7
CSCV7	9.2
CSCV8	4.8
CSF	PR.IP-1

CSF	PR.PT-3
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
-- INFO --
- module: "overlayfs" exists in:
  - "/usr/lib/modules/6.17.0-1018-azure/kernel/fs"

- Audit Result:
  ** FAIL **
- Reason(s) for audit failure:
  - kernel module: "overlayfs" is loadable
  - kernel module: "overlayfs" is not deny listed
- Correctly set:
  - kernel module: "overlayfs" is not loaded
```


6.2.2.2 Ensure audit logs are not automatically deleted

Info

The `max_log_file_action` setting determines how to handle the audit log file reaching the max file size. A value of `keep_logs` will rotate the logs but never delete old logs. In high security contexts, the benefits of maintaining a long audit history exceed the cost of storing the audit history.

Solution

Set the following parameter in `/etc/audit/auditd.conf`: `max_log_file_action = keep_logs`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.7
800-171R3	03.03.07
800-53	AU-4
800-53	AU-8
800-53R5	AU-8
CN-L3	8.1.4.3(b)
CSCV7	6.4
CSCV8	8.3
CSF	PR.DS-4
CSF	PR.PT-1
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ISO-27001-2022	A.8.17
ITSG-33	AU-4
ITSG-33	AU-8
LEVEL	2A
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
TBA-FIISB	37.4

Assets

abel-ubuntu-server

Non-compliant file(s):

```
/etc/audit/auditd.conf - regex '^[\s]*max_log_file_action[\s]*=' found - expect
'^[\s]*max_log_file_action[\s]*=[\s]*(?i)keep_logs(?:-i)[\s]*$' not found in the following lines:
    17: max_log_file_action = ROTATE
```

Audits SKIPPED

Audits PASSED

6.2.4.9 Ensure audit tools owner is configured

Info

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records.
Audit tools include custom queries and report generators. Protecting audit information includes identifying and protecting the tools used to view and manipulate log data.
Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Solution

Run the following command to change the owner of the audit tools to the root user: `# chown root /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace /sbin/auditd /sbin/auditd /sbin/auditd /sbin/auditd /sbin/auditd /sbin/auditd`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)

CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10

ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3

NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1
TBA-FIISB	31.4.2

Assets**abel-ubuntu-server**

The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/autrace with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/auditctl, /sbin/auditd, /sbin/augenrules, /sbin/aureport, /sbin/ausearch, /sbin/autrace

6.2.1.1 Ensure auditd packages are installed

Info

auditd is the userspace component to the Linux Auditing System. It's responsible for writing audit records to the disk. The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

Solution

Run the following command to Install auditd and audispd-plugins # apt install auditd audispd-plugins

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-3
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)

CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(a)
CN-L3	8.1.4.3(b)
CSCV7	6.2
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1
CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15

ITSG-33	AU-2
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T3.6.2
NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a
NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3

PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
PASSED - dpkg check auditd
The command '/bin/dpkg -s auditd 2>&1 | /bin/grep -E '^(Status:|not installed)'' returned :
```

```
Status: install ok installed
```

```
-----
PASSED - audispd-plugins
The command '/bin/dpkg -s audispd-plugins 2>&1 | /bin/grep -E '^(Status:|not installed)''
returned :
```

```
Status: install ok installed
```

6.2.3.3 Ensure events that modify the sudo log file are collected

Info

Monitor the sudo log file.

If the system has been properly configured to disable the use of the su command and force all administrators to have to log in first and then use sudo to execute privileged commands, then all administrator commands will be logged to /var/log/sudo.log.

Any time a command is executed, an audit event will be triggered as the /var/log/sudo.log file will be opened for write and the executed administration command will be written to the log. Changes in /var/log/sudo.log indicate that an administrator has executed a command or the log file itself has been tampered with.

Administrators will want to correlate the events written to the audit trail with the records written to /var/log/sudo.log to verify if unauthorized commands have been executed.

Solution

Note: This recommendation requires that the sudo logfile is configured.

See guidance provided in the recommendation "Ensure sudo log file exists" Edit or create a file in the /etc/audit/rules.d/ directory, ending in .rules extension, with the relevant rules to monitor events that modify the sudo log file. Example: # { SUDO_LOG_FILE=\$(grep -r logfile /etc/sudoers* | sed -e 's/.*/logfile=//;s/,/? .*/' -e 's/'//g') [-n "\${SUDO_LOG_FILE}"] && printf " -w \${SUDO_LOG_FILE} -p wa -k sudo_log_file " >> /etc/audit/rules.d/50-sudo.rules || printf "ERROR: Variable 'SUDO_LOG_FILE' is unset.\n" } Merge and load the rules into active configuration: # augenrules --load Check if reboot is required. # if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then printf "Reboot required to load rules\n"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
800-53R5	AU-3(1)
800-53R5	AU-7
800-53R5	AU-12
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)

CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	4.9
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2A
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c

NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
PASSED - auditctl sudo log
The command script with multiple lines returned :

ERROR: Variable 'SUDO_LOG_FILE' is unset.
pass

-----
PASSED - sudo log
The command script with multiple lines returned :

ERROR: Variable 'SUDO_LOG_FILE' is unset.
pass
```


6.2.4.10 Ensure audit tools group owner is configured

Info

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records.
Audit tools include custom queries and report generators. Protecting audit information includes identifying and protecting the tools used to view and manipulate log data.
Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Solution

Run the following command to change group ownership to the group root : # chgrp root /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace /sbin/auditd /sbin/auditrules

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)

CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10

ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3

NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1
TBA-FIISB	31.4.2

Assets**abel-ubuntu-server**

The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/autrace with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/auditctl, /sbin/auditd, /sbin/augenrules, /sbin/aureport, /sbin/ausearch, /sbin/autrace

6.2.4.5 Ensure audit configuration files mode is configured

Info

Audit configuration files control auditd and what events are audited. Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events. Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log.

Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Solution

Run the following command to remove more permissive mode than 0640 from the audit configuration files: #
find /etc/audit/ -type f \(-name '*.conf' -o -name '*.rules' \) -exec chmod u-x,g-wx,o-rwx {} +

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)

CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7

ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1

NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
** PASS **
- All audit configuration files are mode: "640" or more restrictive

1.7.1 Ensure GDM is removed

Info

The GNOME Display Manager (GDM) is a program that manages graphical display servers and handles graphical user logins. If a Graphical User Interface (GUI) is not required, it should be removed to reduce the attack surface of the system.

Solution

Run the following commands to uninstall gdm3 and remove unused dependencies: `# apt purge gdm3 # apt autoremove gdm3` Impact: Removing the GNOME Display manager will remove the Graphical User Interface (GUI) from the system.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.4.9
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53	CM-11
800-53R5	CM-11
CSCV7	9.2
CSCV8	4.8
CSF	DE.CM-3
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-02
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19

ISO/IEC-27001	A.12.6.2
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	8.2.1
SWIFT-CSCV1	2.3
SWIFT-CSCV1	5.1

Assets

abel-ubuntu-server

The command `'/bin/dpkg -s gdm3 2>&1 | /bin/grep -E '^(^Status:|not installed)''` returned :

`dpkg-query: package 'gdm3' is not installed and no information is available`

2.1.20 Ensure X window server services are not in use

Info

The X Window System provides a Graphical User Interface (GUI) where users can have multiple windows in which to run programs and various add on.

The X Windows system is typically used on workstations where users login, but not on servers where users typically do not login. Unless your organization specifically requires graphical login access via X Windows, remove it to reduce the potential attack surface.

Solution

- IF - a Graphical Desktop Manager or X-Windows server is not required and approved by local site policy: Run the following command to remove the X Windows Server package: `# apt purge xserver-common` Impact: If a Graphical Desktop Manager (GDM) is in use on the system, there may be a dependency on the `xorg-x11-server-common` package.

If the GDM is required and approved by local site policy, the package should not be removed. Many Linux systems run applications which require a Java runtime.

Some Linux Java packages have a dependency on specific X Windows `xorg-x11-fonts`.

One workaround to avoid this dependency is to use the "headless" Java packages for your specific Java runtime.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.4.9
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53	CM-11
800-53R5	CM-11
CSCV7	2.6
CSCV8	4.8
CSF	DE.CM-3
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
CSF2.0	PR.PS-02
GDPR	32.1.b

HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO/IEC-27001	A.12.6.2
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	8.2.1
SWIFT-CSCV1	2.3
SWIFT-CSCV1	5.1

Assets

abel-ubuntu-server

The command `'/bin/dpkg -s xserver-common 2>&1 | /bin/grep -E '^(Status:|not installed)''` returned :

`dpkg-query: package 'xserver-common' is not installed and no information is available`

6.2.3.21 Ensure the running and on disk configuration is the same

Info

The Audit system have both on disk and running configuration.

It is possible for these configuration settings to differ. Note: Due to the limitations of augenrules and auditctl, it is not absolutely guaranteed that loading the rule sets via augenrules --load will result in all rules being loaded or even that the user will be informed if there was a problem loading the rules. Configuration differences between what is currently running and what is on disk could cause unexpected problems or may give a false impression of compliance requirements.

Solution

If the rules are not aligned across all three () areas, run the following command to merge and load all rules: # augenrules --load Check if reboot is required. if [[\$(auditctl -s | grep "enabled") =~ "2"]]; then echo "Reboot required to load rules"; fi

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171R3	03.03.02a.
800-171R3	03.03.02b.
800-171R3	03.03.03
800-171R3	03.03.06a.
800-53	AU-3
800-53	AU-3(1)
800-53	AU-7
800-53	AU-12
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.2.3(c)
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	8.1.4.3(b)
CSCV7	6.3
CSCV8	8.5
CSF	DE.CM-1
CSF	DE.CM-3

CSF	DE.CM-7
CSF	PR.PT-1
CSF	RS.AN-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.28
ISO-27001-2022	A.8.15
ITSG-33	AU-3
ITSG-33	AU-3(1)
ITSG-33	AU-7
ITSG-33	AU-12
LEVEL	2M
NESA	T3.6.2
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
PCI-DSSV3.2.1	10.1
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1

PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

The command '/sbin/augenrules --check' returned :

/sbin/augenrules: No change

6.2.1.2 Ensure auditd service is enabled and active

Info

Turn on the auditd daemon to record system events. The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

Solution

Run the following commands to unmask, enable and start auditd : # systemctl unmask auditd # systemctl enable auditd # systemctl start auditd

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.3.1
800-171	3.3.2
800-171	3.3.6
800-171	3.14.3
800-171R3	03.03.01
800-171R3	03.03.03
800-171R3	03.03.06a.
800-171R3	03.14.03
800-53	AU-2
800-53	AU-7
800-53	AU-12
800-53	SI-5
800-53R5	AU-2
800-53R5	AU-12
800-53R5	SI-5
CN-L3	7.1.2.3(c)
CN-L3	8.1.4.3(a)
CSCV7	6.2
CSCV7	6.3
CSCV8	8.2
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	ID.RA-1

CSF	ID.RA-2
CSF	ID.RA-3
CSF	PR.PT-1
CSF	RS.AN-3
CSF	RS.CO-5
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	ID.RA-01
CSF2.0	ID.RA-02
CSF2.0	ID.RA-03
CSF2.0	PR.PS-04
CSF2.0	RS.AN-03
CSF2.0	RS.AN-06
CSF2.0	RS.AN-07
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.6
ISO-27001-2022	A.8.8
ISO-27001-2022	A.8.15
ITSG-33	AU-2
ITSG-33	AU-7
ITSG-33	AU-12
ITSG-33	SI-5
LEVEL	2A
NESA	M1.2.2
NESA	M5.5.1
NESA	T7.7.1
NIAV2	AM7
NIAV2	AM11a

NIAV2	AM11b
NIAV2	AM11c
NIAV2	AM11d
NIAV2	AM11e
NIAV2	SS30
NIAV2	VL8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
QCSC-V1	13.2
SWIFT-CSCV1	6.4

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

```
-----
PASSED - active
The command '/bin/systemctl is-active auditd' returned :

active

-----
PASSED - enabled
The command '/bin/systemctl is-enabled auditd' returned :

enabled
```

6.2.4.8 Ensure audit tools mode is configured

Info

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records.
Audit tools include custom queries and report generators. Protecting audit information includes identifying and protecting the tools used to view and manipulate log data.
Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Solution

Run the following command to remove more permissive mode from the audit tools: `# chmod go-w /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace /sbin/auditd /sbin/auditrules`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)

CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10

ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3

NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1
TBA-FIISB	31.4.2

Assets**abel-ubuntu-server**

The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value
The file /sbin/autrace with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/auditctl, /sbin/auditd, /sbin/augenrules, /sbin/aureport, /sbin/ausearch, /sbin/autrace

6.2.4.2 Ensure audit log files owner is configured

Info

Audit log files contain information about the system and system activity. Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Solution

Run the following command to configure the audit log files to be owned by the root user: # [-f /etc/audit/auditd.conf] && find "\$(dirname \$(awk -F '=' '/^\s*log_file/ {print \$2}' /etc/audit/auditd.conf | xargs))" -type f ! -user root -exec chown root {} +

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)

CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2

ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f

NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** PASS **
- * Correctly configured * :
 - All files in "/var/log/audit" are owned by user: "root"

6.2.4.1 Ensure audit log files mode is configured

Info

Audit log files contain information about the system and system activity. Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Solution

Run the following command to remove more permissive mode than 0640 from audit log files: # [-f /etc/audit/auditd.conf] && find "\$(dirname \$(awk -F '=' '/^\s*log_file/ {print \$2}' /etc/audit/auditd.conf | xargs))" -type f -perm /0137 -exec chmod u-x,g-wx,o-rwx {} +

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)

CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7
ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2

ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM3
NIAV2	AM23f

NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** PASS **
 - All files in "/var/log/audit" are mode: "640" or more restrictive

6.2.4.7 Ensure audit configuration files group owner is configured

Info

Audit configuration files control auditd and what events are audited. Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events. Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log.

Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Solution

Run the following command to change group to root : # find /etc/audit/ -type f \(-name '*.conf' -o -name '*.rules' \) ! -group root -exec chgrp root {} +

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)

CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7

ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1

NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command `'/bin/find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -group root | /bin/awk '{print} END { if(NR==0) print "pass" ; else print "fail"}'` returned :

pass

3.2.1 Ensure dccp kernel module is not available

Info

The Datagram Congestion Control Protocol (DCCP) is a transport layer protocol that supports streaming media and telephony. DCCP provides a way to gain access to congestion control, without having to do it at the application layer, but does not provide in-sequence delivery. - IF - the protocol is not required, it is recommended that the drivers not be installed to reduce the potential attack surface.

Solution

Run the following script to unload and disable the dccp module: - IF - the dccp kernel module is available in ANY installed kernel: - Create a file ending in .conf with install dccp /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist dccp in the /etc/modprobe.d/ directory - Run modprobe -r dccp 2>/dev/null; rmmod dccp 2>/dev/null to remove dccp from the kernel - IF - the dccp kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary

```
#!/usr/bin/env bash
a_output2=()
a_output3=()
l_dl=""
l_mod_name="dccp"
l_mod_type="net"
l_mod_path="$(readlink -f /lib/modules/**/kernel/$l_mod_type | sort -u)"
f_module_fix() { l_dl="y"
a_showconfig=()
while IFS= read -r l_showconfig; do
a_showconfig+="${l_showconfig}"
done <<(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+"${l_mod_chk_name}/-/"\b' | if lsmod | grep "${l_mod_chk_name}" && /dev/null; then
a_output2+=(" - unloading kernel module: \"${l_mod_name}\"")
modprobe -r "${l_mod_chk_name}" 2>/dev/null; rmmod "${l_mod_name}" 2>/dev/null
if ! grep -Pq -- '\binstall\h+"${l_mod_chk_name}/-/"\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - setting kernel module: \"${l_mod_name}\" to \"$(readlink -f /bin/false)\"")
printf '%s\n' "install $l_mod_chk_name $(readlink -f /bin/false)" >> /etc/modprobe.d/"${l_mod_name}.conf"
if ! grep -Pq -- '\bblacklist\h+"${l_mod_chk_name}/-/"\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - denylisting kernel module: \"${l_mod_name}\"")
printf '%s\n' "blacklist $l_mod_chk_name" >> /etc/modprobe.d/"${l_mod_name}.conf"
fi }
for l_mod_base_directory in $l_mod_path; do
# Check if the module exists on the system
if [ -d "${l_mod_base_directory}/${l_mod_name}/-/" ] && [ -n "$(ls -A "${l_mod_base_directory}/${l_mod_name}/-/" )" ]; then
a_output3+=(" - \"${l_mod_base_directory}\"")
l_mod_chk_name="${l_mod_name}"
[ "${l_mod_name}" == overlay ] && l_mod_chk_name="${l_mod_name}:-2"
[ "${l_dl}" != "y" ] && f_module_fix
else
printf '%s\n' " - kernel module: \"${l_mod_name}\" doesn't exist in \"${l_mod_base_directory}\""
fi
done
[ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" -- INFO -- " - module: \"${l_mod_name}\" exists in: " "${a_output3[@]}" [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" "${a_output2[@]}" | printf '%s\n' "" " - No changes needed"
printf '%s\n' "" " - remediation of kernel module: \"${l_mod_name}\" complete" "" }
```

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.14.6
800-171	3.14.7
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.14.06
800-53	CM-6
800-53	CM-7
800-53	SI-4
800-53R5	CM-7

800-53R5	SI-4
CN-L3	7.1.3.5(a)
CN-L3	8.1.10.5(b)
CN-L3	8.1.10.6(f)
CSCV7	9.2
CSCV8	4.8
CSF	DE.AE-1
CSF	DE.AE-2
CSF	DE.AE-3
CSF	DE.AE-4
CSF	DE.CM-1
CSF	DE.CM-5
CSF	DE.CM-6
CSF	DE.CM-7
CSF	DE.DP-2
CSF	DE.DP-3
CSF	DE.DP-4
CSF	DE.DP-5
CSF	ID.RA-1
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.IP-8
CSF	PR.PT-3
CSF	RS.AN-1
CSF	RS.CO-3
CSF2.0	DE.AE-02
CSF2.0	DE.AE-03
CSF2.0	DE.CM-01
CSF2.0	DE.CM-06
CSF2.0	DE.CM-09
CSF2.0	ID.IM-01

CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	ID.RA-01
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.16
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	SI-4
LEVEL	2A
NESA	M1.2.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	5.2.3
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** PASS **
- kernel module: "dccp" doesn't exist in "/usr/lib/modules/6.17.0-1018-azure/kernel/net"

CIS_Ubuntu_Linux_24.04_LTS_v1.0.0_L2_Server.audit from CIS Ubuntu Linux 24.04 LTS 1.0.0

Info

Solution

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

Assets

abel-ubuntu-server

All of the following must pass to satisfy this requirement:

PASSED - Check distribution release

Compliant file(s):

```
/etc/lsb-release - regex '^[\s]*DISTRIB_RELEASE[\s]*=' found - expect  
'^[\s]*DISTRIB_RELEASE[\s]*=[\s]*24.04[\s]*$' found in the following lines:  
2: DISTRIB_RELEASE=24.04
```

1.1.1.7 Ensure squashfs kernel module is not available

Info

The squashfs filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A squashfs image can be used without having to first decompress the image. Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Solution

Run the following script to unload and disable the udf module: - IF - the squashfs kernel module is available in ANY installed kernel: - Create a file ending in .conf with install squashfs /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist squashfs in the /etc/modprobe.d/ directory - Run modprobe -r squashfs 2>/dev/null; rmmod squashfs 2>/dev/null to remove squashfs from the kernel - IF - the squashfs kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary

```
#!/usr/bin/env bash
a_output2=()
a_output3=()
l_dl=""
l_mod_name="squashfs"
l_mod_type="fs"
l_mod_path="$(readlink -f /lib/modules/**/kernel/$l_mod_type | sort -u)"
f_module_fix()
{
l_dl="y"
a_showconfig=()
while IFS= read -r l_showconfig; do
a_showconfig+=("$l_showconfig")
done <
<(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+""${l_mod_chk_name}/-/__""\b') if [ ! smod |
grep "$l_mod_chk_name" &> /dev/null; then
a_output2+=(" - unloading kernel module: \"$l_mod_name\"")
modprobe -r "$l_mod_chk_name" 2>/dev/null; rmmod "$l_mod_name" 2>/dev/null
fi
if ! grep -Pq -- '\binstall\h+""${l_mod_chk_name}/-/__""\h+(Vusr)?VbinV(true|false)\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - setting kernel module: \"$l_mod_name\" to \"$(readlink -f /bin/false)\"")
printf '%s\n' "install $l_mod_chk_name $(readlink -f /bin/false)" >> /etc/modprobe.d/"$l_mod_name".conf
fi
if ! grep -Pq -- '\bblacklist\h+""${l_mod_chk_name}/-/__""\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - denylisting kernel module: \"$l_mod_name\"")
printf '%s\n' "blacklist $l_mod_chk_name" >> /etc/modprobe.d/"$l_mod_name".conf
fi
}
for l_mod_base_directory in $l_mod_path; do
# Check if the module exists on the system
if [ -d "$l_mod_base_directory/${l_mod_name}/-/__" ] && [ -n "$(ls -A "$l_mod_base_directory/${l_mod_name}/-/__")" ]; then
a_output3+=(" - \"$l_mod_base_directory\"")
l_mod_chk_name="$l_mod_name"
[ "$l_mod_name" == overlay ] && l_mod_chk_name="${l_mod_name::-2}"
[ "$l_dl" != "y" ] && f_module_fix
else
printf '%s\n' " - kernel module: \"$l_mod_name\" doesn't exist in \"$l_mod_base_directory\""
fi
done
[ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" -- INFO -- " - module: \"$l_mod_name\" exists in: " "${a_output3[@]}" [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" "${a_output2[@]}" | | printf '%s\n' "" " - No changes needed"
printf '%s\n' "" " - remediation of kernel module: \"$l_mod_name\" complete" ""
}
Impact: As Snap packages utilize squashfs as a compressed filesystem, disabling squashfs will cause Snap packages to fail. Snap application packages of software are self-contained and work across a range of Linux distributions. This is unlike traditional Linux package management approaches, like APT or RPM, which require specifically adapted packages per Linux distribution on an application update and delay therefore application deployment from developers to their software's end-user. Snaps themselves have no dependency on any external store ("App store"), can be obtained from any source and can be therefore used for upstream software deployment.
```

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.02
800-171R3	03.04.06
800-53	CM-6
800-53	CM-7
800-53R5	CM-7
CSCV7	9.2
CSCV8	4.8

CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6
ITSG-33	CM-7
LEVEL	2A
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** PASS **
- kernel module: "squashfs" doesn't exist in "/usr/lib/modules/6.17.0-1018-azure/kernel/fs"

3.2.3 Ensure rds kernel module is not available

Info

The Reliable Datagram Sockets (RDS) protocol is a transport layer protocol designed to provide low-latency, high-bandwidth communications between cluster nodes.

It was developed by the Oracle Corporation. - IF - the protocol is not being used, it is recommended that kernel module not be loaded, disabling the service to reduce the potential attack surface.

Solution

Run the following script to unload and disable the rds module: - IF - the rds kernel module is available in ANY installed kernel: - Create a file ending in .conf with install rds /bin/false in the /etc/modprobe.d/ directory - Create a file ending in .conf with blacklist rds in the /etc/modprobe.d/ directory - Run modprobe -r rds 2>/dev/null; rmmod rds 2>/dev/null to remove rds from the kernel - IF - the rds kernel module is not available on the system, or pre-compiled into the kernel, no remediation is necessary

```
#!/usr/bin/env bash
a_output2=()
a_output3=()
l_dl=""
l_mod_name="rds"
l_mod_type="net"
l_mod_path="$(readlink -f /lib/modules/**/kernel/$l_mod_type | sort -u)"
f_module_fix() { l_dl="y"
a_showconfig=()
while IFS= read -r l_showconfig; do
a_showconfig+="${l_showconfig}"
done < <(modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+${l_mod_chk_name}/-/_'\b)
if lsmod | grep "${l_mod_chk_name}" &> /dev/null; then
a_output2+=(" - unloading kernel module: \"${l_mod_name}\"")
modprobe -r "${l_mod_chk_name}" 2>/dev/null;
rmmod "${l_mod_name}" 2>/dev/null
if ! grep -Pq -- '\binstall\h+${l_mod_chk_name}/-/_'\b(\Vusr)?\Vbin\(\true|false\)\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - setting kernel module: \"${l_mod_name}\" to \"$(readlink -f /bin/false)\"")
printf '%s\n' "install ${l_mod_chk_name} $(readlink -f /bin/false)" >> /etc/modprobe.d/"${l_mod_name}.conf"
if ! grep -Pq -- '\bblacklist\h+${l_mod_chk_name}/-/_'\b' <<< "${a_showconfig[*]}"; then
a_output2+=(" - denylisting kernel module: \"${l_mod_name}\"")
printf '%s\n' "blacklist ${l_mod_chk_name}" >> /etc/modprobe.d/"${l_mod_name}.conf"
fi
}
for l_mod_base_directory in $l_mod_path; do
# Check if the module exists on the system
if [ -d "${l_mod_base_directory}/${l_mod_name}/-/_/" ] && [ -n "$(ls -A "${l_mod_base_directory}/${l_mod_name}/-/_/")" ]; then
a_output3+=(" - \"${l_mod_base_directory}/${l_mod_name}\" [ [ "${l_mod_name}" =~ overlay ] && l_mod_chk_name="${l_mod_name}:" ] [ "${l_dl}" != "y" ] && f_module_fix
else
printf '%s\n' " - kernel module: \"${l_mod_name}\" doesn't exist in \"${l_mod_base_directory}\""
fi
done
[ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" -- INFO -- " - module: \"${l_mod_name}\" exists in: " "${a_output3[@]}" [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" "${a_output2[@]}" || printf '%s\n' "" " - No changes needed"
printf '%s\n' "" " - remediation of kernel module: \"${l_mod_name}\" complete" "" }
```

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.14.6
800-171	3.14.7
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.14.06
800-53	CM-6
800-53	CM-7
800-53	SI-4
800-53R5	CM-7
800-53R5	SI-4

CN-L3	7.1.3.5(a)
CN-L3	8.1.10.5(b)
CN-L3	8.1.10.6(f)
CSCV7	9.2
CSCV8	4.8
CSF	DE.AE-1
CSF	DE.AE-2
CSF	DE.AE-3
CSF	DE.AE-4
CSF	DE.CM-1
CSF	DE.CM-5
CSF	DE.CM-6
CSF	DE.CM-7
CSF	DE.DP-2
CSF	DE.DP-3
CSF	DE.DP-4
CSF	DE.DP-5
CSF	ID.RA-1
CSF	PR.DS-5
CSF	PR.IP-1
CSF	PR.IP-8
CSF	PR.PT-3
CSF	RS.AN-1
CSF	RS.CO-3
CSF2.0	DE.AE-02
CSF2.0	DE.AE-03
CSF2.0	DE.CM-01
CSF2.0	DE.CM-06
CSF2.0	DE.CM-09
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02

CSF2.0	ID.IM-03
CSF2.0	ID.RA-01
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.PS-01
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.16
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	SI-4
LEVEL	2A
NESA	M1.2.2
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	5.2.3
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	10.2.1
QCSC-V1	11.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
 - ** PASS **
 - kernel module: "rds" doesn't exist in "/usr/lib/modules/6.17.0-1018-azure/kernel/net"

6.2.4.4 Ensure the audit log file directory mode is configured

Info

The audit log directory contains audit log files. Audit information includes all information including: audit records, audit settings and audit reports.

This information is needed to successfully audit system activity.

This information must be protected from unauthorized modification or deletion.

If this information were to be compromised, forensic analysis and discovery of the true source of potentially malicious system activity is impossible to achieve.

Solution

Run the following command to configure the audit log directory to have a mode of "0750" or less permissive: `# chmod g-w,o-rwx "$(dirname "$(awk -F= '/^\s*log_file\s*/{print $2}' /etc/audit/auditd.conf | xargs))"`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)

CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7

ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1

NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

- Audit Result:
** PASS **
- Directory: "/var/log/audit" is mode: "0750"
(should be mode: "750" or more restrictive)

6.2.4.6 Ensure audit configuration files owner is configured

Info

Audit configuration files control auditd and what events are audited. Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events. Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log.

Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Solution

Run the following command to change ownership to root user: `# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -user root -exec chown root {} +`

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)

CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7

ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1

NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command `'/bin/find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -user root | /bin/awk '{print} END { if(NR==0) print "pass" ; else print "fail"}'` returned :

pass

6.2.4.3 Ensure audit log files group owner is configured

Info

Audit log files contain information about the system and system activity. Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Solution

Run the following command to configure the audit log files to be group owned by adm : # find \$(dirname \$(awk -F"=" ' /^\s*log_file/ {print \$2}' /etc/audit/auditd.conf | xargs)) -type f \(! -group adm -a ! -group root \) -exec chgrp adm {} + Run the following command to set the log_group parameter in the audit configuration file to log_group = adm : # sed -ri 's/^s*#\s*log_group\s*=\s*\S+(\s*#.*)?.*\$/log_group = adm\1/' /etc/audit/auditd.conf Run the following command to restart the audit daemon to reload the configuration file: # systemctl restart auditd

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.1.1
800-171	3.1.4
800-171	3.1.5
800-171	3.3.1
800-171	3.3.2
800-171	3.8.1
800-171	3.8.2
800-171	3.8.3
800-171R3	03.01.02
800-171R3	03.01.04
800-171R3	03.01.05a.
800-171R3	03.03.02a.
800-171R3	03.08.02
800-53	AC-3
800-53	AC-5
800-53	AC-6
800-53	AU-3
800-53	MP-2
800-53R5	AU-3
CN-L3	7.1.2.3(a)
CN-L3	7.1.2.3(b)
CN-L3	7.1.3.2(b)

CN-L3	7.1.3.2(g)
CN-L3	7.1.3.3(a)
CN-L3	8.1.4.2(d)
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.3(b)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.1.10.6(a)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSCV7	14.6
CSCV8	3.3
CSF	PR.AC-4
CSF	PR.DS-5
CSF	PR.PT-1
CSF	PR.PT-2
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
CSF2.0	PR.PS-04
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.3
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.28
ISO-27001-2022	A.5.33
ISO-27001-2022	A.7.7

ISO-27001-2022	A.7.10
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.15
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.6.1.2
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
ITSG-33	AC-5
ITSG-33	AC-6
ITSG-33	AU-3
ITSG-33	MP-2
ITSG-33	MP-2a.
LEVEL	2A
NESA	T1.3.2
NESA	T1.3.3
NESA	T1.4.1
NESA	T3.6.2
NESA	T4.2.1
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM1

NIAV2	AM3
NIAV2	AM23f
NIAV2	AM34a
NIAV2	AM34b
NIAV2	AM34c
NIAV2	AM34d
NIAV2	AM34e
NIAV2	AM34f
NIAV2	AM34g
NIAV2	SS13c
NIAV2	SS15c
NIAV2	SS29
PCI-DSSV3.2.1	7.1.2
PCI-DSSV3.2.1	10.3
PCI-DSSV3.2.1	10.3.1
PCI-DSSV3.2.1	10.3.2
PCI-DSSV3.2.1	10.3.3
PCI-DSSV3.2.1	10.3.4
PCI-DSSV3.2.1	10.3.5
PCI-DSSV3.2.1	10.3.6
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
PCI-DSSV4.0	10.2.2
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
SWIFT-CSCV1	5.1
SWIFT-CSCV1	6.4
TBA-FIISB	31.1

TBA-FIISB 31.4.2

TBA-FIISB 31.4.3

Assets

abel-ubuntu-server

The command script with multiple lines returned :

```
- Audit Result:
** PASS **
- * Correctly configured * :
- Log file group correctly set to: "adm" in "/etc/audit/auditd.conf"
- All files in "/var/log/audit" are group owned by group: "root or adm"
```


5.1.9 Ensure sshd GSSAPIAuthentication is disabled

Info

The GSSAPIAuthentication parameter specifies whether user authentication based on GSSAPI is allowed. Allowing GSSAPI authentication through SSH exposes the system's GSSAPI to remote hosts, and should be disabled to reduce the attack surface of the system.

Solution

Edit the `/etc/ssh/sshd_config` file to set the GSSAPIAuthentication parameter to no above any Include and Match entries as follows: GSSAPIAuthentication no. Note: First occurrence of an option takes precedence, Match set statements withstanding.

If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.1
800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.5.2
800-171R3	03.04.01
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.05.07
800-171R3	03.05.12
800-171R3	03.15.01
800-53	CM-1
800-53	CM-2
800-53	CM-6
800-53	CM-7
800-53	IA-5
800-53	IA-5(1)
800-53R5	CM-1
800-53R5	CM-2
800-53R5	CM-6
800-53R5	CM-7
800-53R5	IA-5

CSCV7	4.4
CSCV8	5.2
CSF	DE.AE-1
CSF	ID.GV-1
CSF	ID.GV-3
CSF	PR.AC-1
CSF	PR.DS-7
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	DE.CM-09
CSF2.0	GV.OC-03
CSF2.0	GV.OV-01
CSF2.0	GV.PO-01
CSF2.0	GV.PO-02
CSF2.0	GV.SC-03
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
CSF2.0	PR.PS-01
GDPR	32.1.b
GDPR	32.4
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.1
ISO-27001-2022	A.5.2
ISO-27001-2022	A.5.4
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17

ISO-27001-2022	A.5.31
ISO-27001-2022	A.5.36
ISO-27001-2022	A.5.37
ISO-27001-2022	A.8.9
ISO-27001-2022	5.2
ISO-27001-2022	5.3
ISO-27001-2022	7.5.1
ISO-27001-2022	7.5.2
ISO-27001-2022	7.5.3
ITSG-33	CM-1
ITSG-33	CM-2
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	IA-5
ITSG-33	IA-5(1)
LEVEL	2A
NESA	M1.2.2
NESA	T3.2.5
NESA	T5.2.3
NESA	T7.5.1
NIAV2	GS8b
NIAV2	SS15a
NIAV2	SS16
NIAV2	VL7a
NIAV2	VL7b
PCI-DSSV3.2.1	2.2.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	7.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3

Assets**abel-ubuntu-server**

The command script with multiple lines returned :

```
port 22: gssapiauthentication no  
Pass
```

5.4.3.1 Ensure nologin is not listed in /etc/shells

Info

/etc/shells is a text file which contains the full pathnames of valid login shells.

This file is consulted by chsh and available to be queried by other programs. Be aware that there are programs which consult this file to find out if a user is a normal user; for example, FTP daemons traditionally disallow access to users with shells not included in this file. A user can use chsh to change their configured shell. If a user has a shell configured that isn't in /etc/shells, then the system assumes that they're somehow restricted. In the case of chsh it means that the user cannot change that value. Other programs might query that list and apply similar restrictions. By putting nologin in /etc/shells, any user that has nologin as its shell is considered a full, unrestricted user.

This is not the expected behavior for nologin.

Solution

Edit /etc/shells and remove any lines that include nologin

See Also

<https://workbench.cisecurity.org/benchmarks/18959>

References

800-171	3.4.1
800-171	3.4.2
800-171	3.4.6
800-171	3.4.7
800-171	3.5.2
800-171R3	03.04.01
800-171R3	03.04.02
800-171R3	03.04.06
800-171R3	03.05.12
800-171R3	03.15.01
800-53	CM-1
800-53	CM-2
800-53	CM-6
800-53	CM-7
800-53	IA-5
800-53R5	CM-1
800-53R5	CM-2
800-53R5	CM-6
800-53R5	CM-7
800-53R5	IA-5
CSF	DE.AE-1

CSF	ID.GV-1
CSF	ID.GV-3
CSF	PR.AC-1
CSF	PR.DS-7
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	DE.CM-09
CSF2.0	GV.OC-03
CSF2.0	GV.OV-01
CSF2.0	GV.PO-01
CSF2.0	GV.PO-02
CSF2.0	GV.SC-03
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
CSF2.0	PR.PS-01
GDPR	32.1.b
GDPR	32.4
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.1
ISO-27001-2022	A.5.2
ISO-27001-2022	A.5.4
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO-27001-2022	A.5.31
ISO-27001-2022	A.5.36
ISO-27001-2022	A.5.37

ISO-27001-2022	A.8.9
ISO-27001-2022	5.2
ISO-27001-2022	5.3
ISO-27001-2022	7.5.1
ISO-27001-2022	7.5.2
ISO-27001-2022	7.5.3
ITSG-33	CM-1
ITSG-33	CM-2
ITSG-33	CM-6
ITSG-33	CM-7
ITSG-33	IA-5
LEVEL	2A
NESA	M1.2.2
NESA	T3.2.5
NESA	T5.2.3
NESA	T7.5.1
NIAV2	GS8b
NIAV2	SS15a
NIAV2	SS16
NIAV2	VL7a
NIAV2	VL7b
PCI-DSSV3.2.1	2.2.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
QCSC-V1	7.2
QCSC-V1	13.2
SWIFT-CSCV1	2.3

Assets

abel-ubuntu-server

The following file(s) do not contain "^\\h*([^\n\r]+)?\\nlogin\b":
 /etc/shells

Audits ERROR,INFO,WARNING